# Margins365 — QA & Testing Prompt v20

**Full-site build verification: is everything built, and does it all work?**

| | |
|---|---|
| **For** | QA & Testing team |
| **From** | Business & Product (on behalf of Akthar Uddin) |
| **Date** | 11 November 2026 (Europe/London) |
| **Baseline** | **Product Specification v20 FINAL** (`/workspace/v20/Margins365-Spec-v20.md`, K1–K86, including section 23, the product architecture, and 23.19 for K80–K86), the SEO spec v20 (K75–K79), the v20 legal documents, and the v19 acceptance tests it keeps |
| **Status** | Ready to run. All v20 decisions are made (section 3.3); K84's visitor confirmation without message text awaits Akthar's OK |
| **Test cases** | 520 (35 added on 11 Nov 2026 for K80–K86 and fix D-1: suite MOB 13, NAV 4, HELP 8, AUTH 5, EML 4, OFF 1) |

---

## 1. Your brief (read this first)

You are the QA & Testing team for **Margins365**, a subscription web app at **https://margins365.com**. It shows online sellers (Shopify, Amazon, Etsy) their true profit, a Health Score from 0 to 100, and the margin leaks that cost them most, ranked in pounds.

Your job is to **prove, with evidence, that every feature in the spec has been built and works end to end**. That covers the public site, sign-in, checkout and billing, shops and seats, imports, the calculations, the Control room, cancellation and data deletion, emails, the legal documents, every device size and security. Do not assume something works because it shows on screen. Many features can look finished while the server does nothing behind them.

**How to work**

1. **Test against the spec, not against the current build.** Where the build and this prompt disagree, raise a defect. Do not "fix" the expected result to match the build.
2. **Evidence for every result.** Each Pass or Fail needs a screenshot or video, the URL, the device and browser, the account used and the time (Europe/London). A Pass with no evidence counts as Not run.
3. **Check what happens behind the screen.** For anything involving money, limits, permissions or deletion, confirm what the server and Stripe did (Stripe test dashboard, the email received,

the database or admin view, network requests). A message on screen is not proof.
4. **Try to break it.** Every suite includes boundary, error and abuse cases. Run them all, not just the happy path.
5. **Never test on real customer data or real cards.** Use Stripe test mode and the test accounts in section 5. The only live-mode checks are the low-risk ones in suite CHK, run by Akthar or with his written go-ahead.
6. **Do not change the spec or contact customers.** Raise questions through the defect log, tagged `SPEC-QUESTION`.
7. **Use plain English** in defect reports. Each report should make sense to someone who has not seen the screen.

**Result codes:** Pass · Fail · Blocked (the test can't run, give the reason) · Not applicable (give the reason).

**Priority** (use on test cases and defects)

| Priority | Meaning | Examples |
|---|---|---|
| **P0 — Critical** | Money, legal, privacy, security or data loss. Or a core journey can't be completed. Blocks release. | Wrong amount charged; cancelled trial still charged; another account's data visible; legal page missing; sign-up impossible |
| **P1 — High** | A required feature is missing or broken, with no reasonable workaround. Blocks release. | Shop switcher missing on Scale; refresh drops you on Home; contact form doesn't send |
| **P2 — Medium** | A feature works only partly, or has a workaround; wrong copy that changes meaning; an accessibility failure off the core journeys | Wrong error text; one breakpoint has clipped text |
| **P3 — Low** | Cosmetic, or a minor wording issue that doesn't change meaning | Spacing; inconsistent capitalisation |

---

## 2. Scope

**In scope:** everything a visitor, trial user, paying customer, team member or administrator can see or do on margins365.com. That includes the server, Stripe, Amazon SES email, Google sign-in, the legal documents, the old marginos.online domain, and the data lifecycle from upload to deletion.

**Out of scope for this pass:**

- the TikTok Shop UK Excel importer. It stays "coming soon" (K53). Test only that public copy

says so (suite IMP).
- post-launch candidates in spec 9.2 (weekly email, ad connections, alerts, accountant export). Raise a defect if any of them appears on the site.
- penetration testing by an outside firm. This prompt covers in-house security checks only.

---

## 3. What you are testing against

### 3.1 Sources, in order of precedence

1. **Product Specification v20 FINAL**, and especially **section 23 (product architecture)**: the route map, account menu, shops, seats and invites, Info, onboarding, Control room, upload, Plan & billing, trial lifecycle, cancellation, Help centre, emails and data retention. Its acceptance IDs (IA-, SH-, ST-, IN-, ON-, CR-, UP-, PB-, TR-, CA-, HC-, FO-, LG-) are referenced throughout. Where v20 and v19 disagree, v20 wins. K64 and K65 replace the 7 Nov 2026 Help centre and footer handoff.
2. **The v20 requirements summarised in section 3.2** (K59–K74).
3. **The v19 sections that v20 carries forward unchanged**, including sections 3, 5, 6, 10, 12 (calculations, limits, subscriptions, cancellation, deletion), 15 (devices and UX), 16 (imports and fees), 17 (sample data) and 22 (brand). The spec's own acceptance IDs (L1–L17, S1–S75, D1–D13) are referenced throughout.
4. **SEO & Discoverability Spec v20** (`/workspace/v20/Margins365-SEO-v20.md`, K75–K79) and spec 23.14–23.18 for suites SEO, PCALC, CONS and ANL: exact titles, descriptions, robots, sitemap, redirects, structured data and speed targets.
5. **Legal documents** (Terms, Privacy Policy, Refunds & cancellation, DPA & subprocessors). Akthar has approved them, judged against UK and EU rules. They must match what the product actually does.

### 3.2 v20 requirements (approved by Akthar, 11 Nov 2026)

| Ref | Requirement |
|---|---|
| **V1** | **Brand:** "Margins365" is written as one word everywhere: site, page titles, meta and Open Graph tags, emails (subject, body, From name), PDFs, legal documents, Stripe (product names, Checkout, receipts, statement descriptor where Stripe allows) and the SES From name. No "Margins 365", "MarginOS" or "MarginSeam" is shown to customers. |
| **V2** | **Header navigation:** exactly three items, **Home**, **Sample shop** and **Pricing**. "Sample report" is renamed "Sample shop" everywhere. |
| **V3** | **Home "Start here":** the green area at the bottom of Home is titled "Start here" and keeps its three buttons. **Compare plans** and **Sample shop** swap positions. |
| **V4** | **Scroll to top:** every navigation (header, footer, buttons, links, browser back and forward to a |

| Ref | Requirement |
| --- | --- |
| | new page) lands at the **top** of the new page. The exceptions are in-page anchors, such as the Pricing header button that scrolls to the plans. |
| **V5** | **Real routes and refresh:** every page has its own URL. Refresh keeps you on the same page. Deep links work. Back and forward work. Signed-in pages survive a refresh while you stay signed in. |
| **V6** | **Footer:** shows "© 2026 Margins365. All rights reserved." The year updates each year. The sentence "Margins 365. Plans from £39/month including VAT after trial. Cancel in Plan & billing — there is no email cancellation route." is removed with nothing in its place. There is no **Contact** link. The Legal column has Terms, Privacy, Refunds & cancellation and DPA / subprocessors. The Help column has Help centre and Sign in. Every link works. |
| **V7** | **Help centre page (new, public):** holds the **Hard limits & billing FAQ** (moved from Pricing) and a **contact form**. |
| **V8** | **Contact form (23.11):** Name (required), Phone (optional), Business name (optional), Email (required), Country (required, from a list), Message (required, 10–5,000 characters). Each submission is stored, then sent through SES to **info.marginos@gmail.com** with reply-to set to the visitor. A **confirmation without the message text is emailed to the visitor** (K84). A confirmation **pop-up** appears. Spam protection is a honeypot plus a minimum fill time. Limits are 5 per IP and 3 per email per hour. Messages are kept for 12 months. |
| **V9** | **Sample shop page (K66):** the green button in the opening section reads **"Start your own shop"** (signed out), **"Choose a plan"** (signed in with no plan) or **"Go to Control room"** (trial or paid). At the bottom of the first dashboard section is a **shop-icon button**, at least 44×44 px, whose accessible name and tooltip are **"Open Sample Shop"**. It opens `/app/sample` (after sign-in if you're signed out). The signed-out header primary stays "Start 14-day free trial". |
| **V10** | **Signed in with a trial or a paid plan:** "Start 14-day free trial" appears **nowhere** (header, banner, pages, footer, emails' calls to action). |
| **V11** | **Top-right green button** shows the **business name** and opens the account menu (23.1). Until a business name is saved it shows the user's first name, then the email. |
| **V12** | **On Scale**, that button also holds the **shop switcher**: list the shops, switch between them, add a shop up to the limit. |
| **V13** | **The account menu** has **Info** and **Control room**. The Control room is **one click** away from every signed-in page, through the menu and through the logo (which goes to `/app` when you're signed in). |

| Ref | Requirement |
|---|---|
| V14 | **Signed-in identity** is the **business name**, not the email, everywhere the user is identified (header, menus, sidebars, team list for the owner's own row, email greetings). |
| V15 | **Shops and multi-shop (23.2):** Starter, Growth and Pro get 1 shop. Scale gets up to 3. Add, rename, switch and remove, plus an "All shops" view on Scale. The order limit is counted **across the whole account on every plan**. Platform slots apply per shop. |
| V16 | **Seats, roles and invites (23.3):** Starter 1, Growth 1, Pro 2, Scale 5. Pending invites count as seats. Invites expire after 7 days. One owner per account. The permissions are in the 23.3 table. A person belongs to one account at a time. |
| V17 | **Trial = the tier selected.** A Starter trial gets Starter features and Starter's limits, and the same for every tier. This **reverses K52** (the Pro reverse trial). Keep Pro, the Pro trial label, "Every trial includes Pro features" and the "features that will lock" reminder list are all removed. |
| V18 | **Info (23.4):** required: your name, business name, country, email, home currency and time zone. Optional: phone, business address, VAT number, website. Sign-up asks only for email and password (or Google) plus acceptance of the Terms. The rest is collected in first-run (23.5). |
| V19 | **Cancellation reason (23.10):** an optional "Why are you cancelling?" picker with 8 options, plus optional free text of up to 500 characters, on the single confirmation screen. It never blocks or slows down cancelling. |
| V20 | **Founding offer (12.5C):** monthly payments 1–6 at 50% (£19.50 / £39.50 / £64.50 / £99.50), then the full price. Annual: 25% off the first year (£292.50 / £592.50 / £967.50 / £1,492.50), then the full price. 100 places, one per account. A place is **reserved** at trial start, **confirmed** at the first payment, and **released** on trial cancellation, final failure of the first payment, or a first-payment refund. The count is enforced on the server and transactional. The display shows the real "[n] places left". A "Founding price ends soon" email goes 14 days before the first full-price payment. Reverses K42. |
| V21 | **Retire marginos.online:** move fully to margins365.com. No customer-facing reference to marginos.online is left in links, emails, Google OAuth, Stripe or SES. |
| V22 | **Legal documents on the site:** Terms, Privacy Policy, Refunds & cancellation, DPA & subprocessors, and a Cookie notice (if cookies or similar storage are used) are published. They can be read **before sign-up and at checkout**, without signing in or paying. A customer-specific signed DPA may sit behind sign-in. Each document shows its version and effective date and matches the live product. |
| V23 | **SEO and discoverability (K75, approved 11 Nov 2026, 14:38):** public pages are prerendered HTML with their own title, description, H1, canonical, Open Graph/Twitter tags and |

| Ref | Requirement |
| --- | --- |
| | JSON-LD; real `<a href>` links; robots.txt, XML sitemap and real 404s; one canonical host with 301 redirects; favicon set and manifest; Core Web Vitals "good" on mobile; Search Console and Bing verified. Details: SEO spec v20. |
| **V24** | **Free public calculators (K76, Phase 2):** Etsy UK, Amazon UK, Shopify UK and ecommerce margin calculators that use the product's own calculation module and 16.2 presets; nothing entered leaves the browser (spec 23.15). |
| **V25** | **Landing pages and help articles (K77, Phase 2):** `/profit-leak-checklist`, `/multi-channel-profit` and `/help/<topic>` articles; **no competitor comparison page** (spec 23.16). |
| **V26** | **Home H1 (K78):** "Know your true profit and where it leaks" (spec 23.17). |
| **V27** | **Analytics and consent (K79):** Plausible Analytics on public pages only after "Accept analytics"; equal Accept/Reject; Cookie settings in the footer; legal texts v20.1 (spec 23.18). |
| **V28** | **Phones and pop-ups (K80):** every pop-up fits the visible screen, scrolls inside, keeps its buttons reachable and locks the page behind; site-wide mobile check (spec 23.19.1). |
| **V29** | **Banner removed (K81):** no "14 days free. Cancel before day 14 and pay nothing. From £39/mo" banner anywhere; trial terms stay on Pricing, the plans pop-up and Checkout (23.19.2). |
| **V30** | **Open at the top, instantly (K82):** every page change lands at the top with no animated scroll (23.19.3). |
| **V31** | **Suggest a feature (K83)** is stored and emailed to info.marginos@gmail.com with account context (23.19.4). |
| **V32** | **Contact us (K84)** is sent server-side to info.marginos@gmail.com signed in and out; the visitor gets a confirmation without the message text; in-page pop-up; spam protection (23.19.5). |
| **V33** | **Forgot password (K85)** works end to end with no browser-only fallbacks and a server-built margins365.com link (23.19.6). |
| **V34** | **Email (K86):** SES identity verified, DKIM and MAIL FROM successful, production access, every email passes SPF, DKIM and DMARC (23.19.7). |

### 3.3 Decisions made since the first draft

- **Founding offer (V20, K72):** fully defined in spec 12.5C, including annual handling and the rules for reserving and releasing places.
- **Sample shop buttons (V9, K66):** the text is decided.

- **Full functional design:** spec v20 section 23. Wherever this prompt says "per the v20 design", use section 23. If a detail isn't defined there, log a `SPEC-QUESTION` rather than guessing.

### 3.4 Known gaps on the live site today (11 Nov 2026), expected to fail until rebuilt

Business & Product found these on the live site and in its published code bundle. Re-test them first. Each is an **expected failure** until Development says it is fixed.

| # | Known gap | Tests |
|---|---|---|
| G1 | **No URL routing.** Every path returns the same app shell, and refresh returns you to Home. robots.txt, sitemap.xml and unknown paths all return the home page HTML with status 200. There is no real 404. | NAV-10–NAV-20, ERR-01 |
| G2 | **No scroll-to-top** when the page changes. You land where you were on the previous page. | NAV-21–NAV-27 |
| G3 | **No screen to add or switch shops, and no seat invite screen**, in the live bundle. The plan settings say 3 shops and 5 seats on Scale, but nothing lets you use them. | SHOP-*, SEAT-* |
| G4 | **The footer links are plain text, not links.** Help centre, Contact, Terms, Privacy, Refunds & cancellation and DPA / subprocessors all do nothing. Only Sign in works. | FTR-*, LEG-* |
| G5 | **The old footer sentence "…Plans from £39/month… no email cancellation route" is still live, and there is no copyright line.** | FTR-02, FTR-03 |
| G6 | **The brand still has a space** ("Margins 365") in the page title, meta description and copy. | BR-* |
| G7 | **Product data appears to be stored in the browser** (localStorage keys `marginos.v6`, an audit log and token stores), with no server endpoints for uploads, shops, seats, cancellation, the billing portal, data export or the contact form. If so, seats, cross-device use, tenant isolation, server-side order counting and guaranteed deletion **cannot** work. Development must confirm. | SEC-*, LIM-*, SEAT-*, DEL-* |
| G8 | **The Confirm cancel step seems to run only in the browser.** No server or Stripe cancel request was found. | CAN-*, CHK-* |
| G9 | **The Stripe webhook resets ended subscriptions to a "free" plan.** The Free plan was retired in v18. | CHK-30, DEL-* |
| G10 | **No security headers** (HSTS, CSP, X-Frame-Options, nosniff, Referrer-Policy) on the | SEC-20– |

| # | Known gap | Tests |
|---|---|---|
| | HTML response. | SEC-24 |
| G11 | **The old founding-price fields are still in the price settings**, and the earlier sample figures disagreed (Health 69 against 36, margin 14.2% against 12.4%). | OFF-*, CALC-20–CALC-24 |
| G12 | **A Cloudflare cookie (`__cf_bm`) is set and localStorage is used**, but there is no cookie notice. | LEG-30–LEG-33, PRIV-10 |
| G13 | **Not search-ready** (SEO audit, 11 Nov 2026): every address returns the same empty HTML shell with the same title ("Margins 365 — margin leak diagnosis"); 0 `<a href>` links (all navigation is buttons); robots.txt, sitemap.xml, favicon.ico and unknown paths return Home with 200; no canonical, Open Graph, structured data or manifest; www and non-www both serve 200; hashed assets not cached; Lighthouse mobile LCP 2.9 s. | SEO-* |
| G14 | **Pop-ups can't scroll on phones** (checked 11 Nov 2026, 17:30): at 390 × 664 the plans pop-up is 1,541 px tall, its top is 893 px above the screen, swipes scroll the page behind, and on iPhone Safari the Start 14-day free trial button is cut off. The same shared containers are used by every pop-up. The cookie banner sits above pop-ups. | MOB-01–MOB-09 |
| G15 | **The "14 days free… From £39/mo" banner is on every public page**, signed in or out; header plus banner take 199 px of a 664 px phone screen. | MOB-11, MOB-12 |
| G16 | **Pages can open at the bottom on iPhone:** whole-page smooth scrolling turns the jump to the top into an animation that Safari can stop part-way. | NAV-33–NAV-35 |
| G17 | **Suggest a feature is stored only**; no email to info.marginos@gmail.com. | HELP-17, HELP-18 |
| G18 | **Account actions fall back to a browser-only demo** when the server errors (reset shows success with no email; sign-in can appear signed in). The reset link is built from a browser-supplied origin (server code). `/reset-password` is 404. | AUTH-21–AUTH-25 |
| G19 | **Contact form:** no honeypot or fill time; browser alert box instead of the pop-up; 4,000-character limit; delivery to info.marginos@gmail.com unproven. | HELP-20–HELP-24 |

| # | Known gap | Tests |
|---|---|---|
| G20 | **SES status unproven:** no apex SPF, DMARC `p=none` without reports, DKIM records not visible from outside, sandbox status unknown. Founding prices also show rounded (£40 instead of £39.50, D-1). | EML-22–EML-25, OFF-17 |

---

## 4. Test environment

| Item | Requirement |
|---|---|
| **Environments** | **Staging** (a copy of production, with Stripe test mode, an SES sandbox or verified test inboxes, a test Google OAuth client and a separate database) for every destructive, billing and deletion test. **Production** for the read-only crawl, brand audit, headers, legal pages, the redirect and the responsive screenshots. Live-money checks run only as CHK-40–CHK-42, with Akthar's go-ahead. |
| **Clock control** | You must be able to move time forward: Stripe **test clocks** for trials, renewals, retries and annual periods, plus a server-side way to run scheduled jobs (deletion, reminders, abandoned imports) on demand. Without clock control, the trial, reminder and deletion suites are Blocked. |
| **Admin access** | A read-only admin view or database access for: entitlement records, order usage sets, shops, seats, contact submissions, feature suggestions, cancellation reasons, the founding-offer counter and deletion tombstones. |
| **Email** | Test inboxes for Gmail, Outlook.com and Apple iCloud, plus one inbox on a custom domain. Raw headers must be viewable (to check SPF, DKIM and DMARC). Use a dark-mode mail client for some checks. |
| **Devices** (15.3) | A recent iPhone (Safari), an Android phone (Chrome, plus Samsung Internet), an iPad in portrait and landscape (Safari), and Windows and macOS desktops. |
| **Browsers** (15.1) | The latest two versions of Chrome, Safari, Edge and Firefox, the latest Samsung Internet, and in-app browsers (Instagram and Facebook) for the Google sign-in fallback. |
| **Viewports** (15.5) | 320×640, 390×844, 768×1024, 834×1194, 1024×768, 1194×834, 1280×800, 1440×900 and 1920×1080. |
| **Tools** | A link crawler, Lighthouse/WebPageTest, axe DevTools plus manual screen readers (VoiceOver on iOS and macOS, NVDA on Windows, TalkBack on Android), browser devtools (network, storage, cookies), an HTTP client for API and permission checks, |

| Item | Requirement |
| --- | --- |
| | mail-tester or similar, and DNS lookup tools. |

## 5. Test accounts and data

### 5.1 Account matrix

Create these on staging. **Each tier** (Starter, Growth, Pro and Scale) needs each **state**:

| State | How to create it | Notes |
| --- | --- | --- |
| Signed out | — | A new private window |
| Signed in, verified, no plan | Sign up without checkout | Must still see "Start 14-day free trial" (15.4) |
| Signed in, unverified | Sign up and don't verify | Uploads and checkout locked |
| Trialing (monthly) | Checkout with a test card | Day 1, day 11 (reminder) and day 14 using a test clock |
| Trialing (annual) | As above, annual | |
| Paid active (monthly / annual) | Advance the test clock past day 15 | |
| Paid with founding 50% (one of the first 100) | Start checkout while the counter is below 100 | Seed the counter in staging |
| Paid at full price (101st or later) | Seed the counter to 100 first | |
| Past due (in retry) | Test card that fails at renewal (`4000 0000 0000 0341`) | |
| Cancelled, access still running | Cancel in Plan & billing | |
| Ended / closed | Advance the clock past the access end | Login must be gone |
| Legacy lifetime | Seed a legacy entitlement | No subscription to cancel (D11) |

**Roles:** an Owner on every tier. A **Member** on Pro (1 member) and Scale (4 members, to fill 5 seats). One **pending invite**. One **removed member**.

**Sign-in methods:** email and password; Google only; Google linked to an existing email account; an unverified Google email (must be refused as verified).

**Scale shops:** 3 shops with different platform mixes (Shopify only; Amazon and Etsy; all three).

**Two separate accounts** (Account A and Account B) for the isolation tests.

### 5.2 Test files (keep them in a shared QA folder; never use real buyer data)

For **Shopify** (Orders CSV and the optional Payments transactions CSV), **Amazon** (Custom Unified Transaction CSV: UK, US and a German translated file) and **Etsy** (Orders CSV, Order Items CSV and the optional Monthly Statement):

- **Valid:** a small file of about 50 orders; a medium file of 1,000; exact boundary files of 499, 500, 501, 1,999, 2,000, 2,001, 4,999, 5,000, 5,001, 14,999, 15,000 and 15,001 unique orders; a file with 2 lines per order (L5); and an overlap file where 100 of 600 orders already exist (L6).
- **Invalid:** a required column missing; headers in a different column order; an unrecognised language; a wrong file type (`.xlsx` renamed `.csv`, `.pdf`, `.exe` renamed `.csv`); an empty file; headers only; every row invalid; a mix of valid and invalid rows; a corrupt encoding; a UTF-8 BOM; EU decimal commas; Etsy "--" amounts; several date formats; amounts with currency signs and thousands separators.
- **Huge:** exactly 100 MB and 100.01 MB; exactly 50,000 rows and 50,001 rows (Q10 defaults).
- **Duplicates:** the same file uploaded twice; the same orders in a different file; a refund-only row for an existing order.
- **Personal data:** a file containing buyer name, email, phone, address, city, postcode, company, tax ID, gift message and order notes. Seed each field with a unique marker such as `QA-PII-EMAIL-7731` so you can search for it later.
- **Security:** a CSV with formula injection (`=HYPERLINK(...)`, `+cmd`, `@SUM`), with HTML or script in product names, and a zip-bomb-style XLSX.
- **Calculation fixtures:** the worked examples in suite CALC, each with its expected results calculated by hand and signed off by Business & Product before you run them.
- **Stripe test cards:** `4242 4242 4242 4242` (succeeds); `4000 0025 0000 3155` (3-D Secure); `4000 0000 0000 9995` (insufficient funds); `4000 0000 0000 0341` (attaches, then fails when charged); `4000 0000 0000 0002` (declined).

---

## 6. Test suites

Each test lists its **ID**, **priority (P)**, **what to do**, the **expected result** and the **spec reference**. Run every test on desktop Chrome first, then on the device matrix where the test or suite RESP says so.

### Suite PUB — Public pages, inventory and every link

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| PUB-01 | P0 | Signed out, open every public route: Home, Sample shop, Pricing, Help centre, Sign in, Terms, Privacy Policy, Refunds & cancellation, DPA & subprocessors, Cookie notice, and the password-reset request and reset pages. | Each has its own URL, loads with status 200, has a unique `<title>` and meta description containing "Margins365", and shows the right content (not the app shell or Home). | 10.1.3, 15.1, V5, V22 |
| PUB-02 | P0 | Crawl the whole site, signed out and then signed in as a Scale owner (follow every `<a>`, button target and footer link, including the PDFs). | Zero 404s, zero 5xx errors, zero links to marginos.online, zero `href="#"` or empty targets, zero dead elements styled as links. Export the crawl report as evidence. | V6, V21, G4 |
| PUB-03 | P1 | For every button and link on every public page, record its label → where it actually goes → where it should go (build a link map). | Every target matches the label. "Sample shop" goes to the Sample shop page. "Compare plans" goes to the Pricing comparison. "Start 14-day free trial" goes to sign-up or checkout. Sign in opens sign-in. | 15.4, V2, V3 |
| PUB-04 | P0 | Signed out, look for account controls on every public page (upload, Start fresh, billing, export, account settings, Control room). | None appear. Signed-out API calls (for example `/api/auth/me`) return no account data. | 5, 10.1.9 |
| PUB-05 | P1 | Home: check the content against 17.5–17.7. That means the differentiation line "Built for single or multi-platform sellers (Shopify, Amazon, Etsy, TikTok coming soon).", the hero sample card, the centred Product section with the headline "See where your profit is leaking.", the six cards with (i) tooltips that open with a tap, Get Started directly under Tools with the two questions, and the "Start here" green area. | All present, word for word. Tooltips and both questions open with a tap or keyboard, not hover only. No "Paid plans unlock the full score breakdown". | S31, S34, S49–S51, S60, V3 |
| PUB-06 | P1 | Home "Start here" area: check the title, the three buttons and their order, | Titled "Start here". Exactly three buttons, with **Compare plans** and | K61, 17.7, |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | signed out and then signed in on a trial or paid plan. | **Sample shop** swapped compared with v19. Signed out, there is one visual primary, "Start 14-day free trial". On a trial or paid plan, the trial button becomes **"Go to Control room"**. Each button goes to its target and lands at the top (V4). | 15.4 |
| PUB-07 | P1 | Pricing: four cards with a monthly/annual toggle; Pro shows "Command centre" above "Most popular"; VAT-inclusive amounts (£39/£390, £79/£790, £129/£1,290, £199/£1,990); the full comparison matrix from 3.1, grouped; Shops and Seats as plain sub-text with no (i) or "?"; no Support target or Email support rows. | All match. **The Hard limits & billing FAQ is no longer on Pricing.** It is on the Help centre (V7). A link to it from Pricing is allowed. | 3, 3.1, S53–S55, S62–S63, V7 |
| PUB-08 | P0 | Pricing copy after V17: search Pricing, the comparison and the cards for "Every trial includes Pro features", "try Pro", "Keep Pro" and the comparison row "14-day free trial includes Pro features". | None of them appears. Trial copy says the trial gives the plan you choose. | V17 |
| PUB-09 | P1 | Pricing header "Start 14-day free trial" (signed out). | Scrolls to the plan cards and focuses Pro. This in-page scroll is the allowed exception to V4. | S53, 15.4 |
| PUB-10 | P0 | Pricing with the founding offer: check that the cards and the comparison show the founding offer honestly (see suite OFF). | The full price and the 50% price are both clear, the 6-month length is stated, and the price from month 7 is stated. The offer disappears once 100 paying users are reached. | V20 |
| PUB-11 | P1 | Sample shop page (`/sample-shop`, formerly Sample report): the heading "What a Margins365 diagnosis looks like", the centred opening section and the first dashboard layout. Check the green opening-section button signed | The opening button reads **"Start your own shop"** (signed out: goes to sign-up, then Choose a plan), **"Choose a plan"** (no plan) or **"Go to Control room"** (trial or paid). The shop-icon button has the accessible name **and** tooltip "Open | K66, S52, S61 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | out, signed in with no plan, and on a trial or paid plan. Check the shop-icon button at the bottom of the first dashboard section. Check the header primary. | Sample Shop", is at least 44×44 px with a visible focus ring, and opens `/app/sample` (after sign-in if signed out). The signed-out header primary stays "Start 14-day free trial". Labelled "Sample data". | |
| PUB-12 | P1 | Search all public copy for "Sample report". | No matches (page titles, nav, buttons, footer, FAQs, emails, meta and alt text included). Every one now reads "Sample shop". | V2 |
| PUB-13 | P0 | Search all public copy for TikTok. | Only "TikTok Shop UK (Beta): Excel import coming soon" (and the K56 line). No export instructions, no TikTok upload option or chip, and TikTok is not counted in platform slots (1 of 3 / up to 2 of 3 / All 3). | K53, S47, Q32 |
| PUB-14 | P1 | Search all copy for retired claims: Free plan, Free countdown, upload counter, lifetime, "yours for life", "No subscription", early-bird, the 25% offer, Support target or SLA, "Start trial" or "Start free trial" (mixed labels), "Card required. Cancel before day 14 to pay nothing.", any invitation to email or reply to cancel, and "Delete account". | None found. (The v20 founding 50% offer is now allowed, but only in its approved form.) | 22.12.8, K41, K46, K50, V20 |
| PUB-15 | P1 | Sticky banner (removed by K81). | **No** sticky banner on any page, signed in or out (the K43 banner "14 days free. Cancel before day 14 and pay nothing. From £39/mo" is retired). See MOB-12. | K81, V29 |
| PUB-16 | P2 | Open Graph and Twitter card tags, the canonical URL and the favicon on every public page. | og:title and og:site_name are "Margins365". The canonical is `https://margins365.com/...`. The image loads. The teal M favicon is used. | V1, V21, 22.6 |
| PUB-17 | P2 | robots.txt and sitemap.xml. | They return real text and XML files (not HTML). The sitemap lists only public routes on margins365.com. Signed-in | V5, G1, V23 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | routes are disallowed or noindex. Full checks in SEO-08 and SEO-09. | |

### Suite FTR — Footer

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| FTR-01 | P1 | On every page that uses the shared footer, signed in and signed out, at phone, iPad and desktop sizes: list the footer columns and items. | Legal: Terms, Privacy, Refunds & cancellation, DPA / subprocessors, Cookies and (once K79 ships) Cookie settings. Help: Help centre, Sign in (or Account when signed in). No Contact link. Navigation column (if present) uses Home, Sample shop and Pricing. | V6, F1 |
| FTR-02 | P1 | Search every page's footer for "Plans from £39/month including VAT after trial". | It is absent, with no replacement marketing sentence. | V6, F2, G5 |
| FTR-03 | P1 | Check the copyright line. | Exactly "© 2026 Margins365. All rights reserved." Move the staging server clock to 2027, and only the year changes. | V6, G5 |
| FTR-04 | P0 | Click every footer link. | Each opens the correct document or page (see LEG for PDF behaviour), with no dead text. It lands at the top of the target page (V4). | V6, G4 |
| FTR-05 | P1 | Footer legal links when signed out. | They open the public legal pages. No "Sign in to view documents" wall in front of mandatory information (see LEG-04). | V22, F10 |
| FTR-06 | P2 | Footer focus order and screen-reader names. | Every link is reachable by keyboard in a logical order, has a visible focus ring and is announced with a meaningful name. Targets are at least 44 px. | 15.1, WCAG 2.4.4, 2.5.8 |

### Suite BR — Brand string audit ("Margins365", one word)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| BR-01 | P1 | Run a full-text search of the rendered HTML on every public and signed-in page for `Margins 365`, `Margins-365`, `MarginOS`, | Zero customer-visible matches. Only "Margins365". | V1, S73 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | `Marginos`, `MarginSeam` and `margins 365` (case-insensitive). | | |
| BR-02 | P1 | Page `<title>` and meta description on every route. | They use "Margins365". The current title "Margins 365 — margin leak diagnosis" is gone. | V1, G6 |
| BR-03 | P1 | Every transactional email (suite EML): From display name, subject, greeting, body, footer and logo alt text. | Each uses "Margins365". The From name is "Margins365". | V1, 22.8 |
| BR-04 | P1 | The PDF report (Growth, Pro, Scale): header wordmark, footer `PRODUCT_NAME` and file metadata (Title, Author, Producer). | "Margins365" throughout. | V1, 22.8 |
| BR-05 | P1 | Legal documents (HTML and PDF): title, body, headers, footers and file names. | "Margins365" one word, including the defined terms ("Margins365", "we", "us"). | V1, V22 |
| BR-06 | P1 | Stripe test mode: product and price names, the Checkout page heading, the customer portal business name, receipt and invoice emails, the invoice PDF, and the statement descriptor. | "Margins365" wherever Stripe shows it. If the statement descriptor still reads `LINK.COM* MARGINOS` (set by Link or Managed Payments), log it as a defect tagged `EXTERNAL-CONFIG` for Akthar to change in Stripe. | V1, V21, 20.5.5 |
| BR-07 | P1 | Google sign-in consent screen: app name, logo, and the homepage, privacy and terms links. | The app name is "Margins365" and the links point to margins365.com. | V1, V21, 20.3 |
| BR-08 | P2 | Browser tab title, PWA or apple-touch names, image alt text, aria-labels and the visually hidden text for the header logo. | "Margins365". | V1 |
| BR-09 | P2 | Error, validation and toast messages, and the 404 page. | Any product name reads "Margins365". | V1 |
| BR-10 | P3 | Internal identifiers (CSS `--mo-*` tokens, localStorage keys, repo paths). | Allowed by K58 as long as they are never shown to customers. List any you find in the report so Akthar can decide. | K58, V21 |

### Suite NAV — Navigation, routes, refresh, scroll and how intuitive it is

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| NAV-01 | P1 | Signed out, check the header on every public page. | The logo goes to Home. Nav is exactly **Home · Sample shop · Pricing**. One primary button, "Start 14-day free trial". Sign in is secondary. The current page is marked (for example with `aria-current="page"`). | V2, 15.4 |
| NAV-02 | P1 | Phone header (≤430 px). | Icon-only logo (28 px). The menu reveals the same three items. The menu can be operated by keyboard and screen reader, focus is trapped while it is open, and Escape closes it. | 22.6, 22.9, V2 |
| NAV-03 | P0 | Signed in on a trial or paid plan, on every public and signed-in page: look for "Start 14-day free trial" (header, sticky banner, Home "Start here", Sample shop page, Pricing cards, footer, empty states). | It appears **nowhere**. Its place is taken by the business-name account button and/or product actions. Pricing cards show "Current plan" and Upgrade or Change plan instead of starting a trial. | V10 |
| NAV-04 | P1 | Signed in, verified, **no** plan yet. | "Start 14-day free trial" or "Choose a plan" is still the primary action. | 15.4 |
| NAV-05 | P1 | Signed in on a legacy lifetime plan. | No trial button. The account button shows the business name. | V10, V11 |
| NAV-06 | P1 | Signed in: check the green account button and its menu, as an owner and as a member, on Starter and on Scale. | The button shows the **business name**. The menu shows the business name, your name and email, a role badge (Owner or Member) and a plan badge (for example "Growth · Trial ends 25 Nov"). Then the shop switcher (Scale only), **Info**, **Control room**, Shops (owner), Team (owner on Pro and Scale; read- | 23.1, IA-4 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | only for members), Plan & billing (owner), Data & privacy (owner; members see their own export only), Help centre and Sign out. It works with the keyboard and screen readers, and closes on Escape or a tap outside. | |
| NAV-07 | P2 | Business name edge cases: 1 character; 80+ characters; emoji; Arabic or Hebrew (right to left); `<script>alert(1)</script>`; `&`. | Long names are shortened with an ellipsis and the full name in an accessible label or tooltip. Right-to-left text displays correctly. HTML is shown as text and never runs. The button stays at least 44 px and doesn't push the header off screen at 320 px. | V11, SEC-30 |
| NAV-08 | P1 | Business name not saved yet (for example a Google sign-up that hasn't finished first-run). | The button shows your first name, or failing that the email, **only** until the business name is saved. First-run asks for it. | IA-3, 23.5 |
| NAV-09 | P0 | Control room in one click: from Home, Pricing, the Help centre, a legal page, Info and Plan & billing, signed in. Use the logo, and use the account menu. | The logo goes to `/app` when you're signed in (Home when signed out). The Control room is one click away from every signed-in page. Record the clicks. | IA-5, CR-1 |
| NAV-10 | P0 | Refresh (F5 and pull-to-refresh) on every public route in the 23.1 route map: `/`, `/sample-shop`, `/pricing`, `/help`, `/sign-in`, `/reset-password`, `/legal/terms`, `/legal/privacy`, `/legal/refunds-and-cancellation`, `/legal/dpa`, `/legal/cookies`. | Each loads directly with its own content, and stays the same after a refresh. | IA-1, K63, G1 |
| NAV-11 | P0 | Refresh on every signed-in route: `/app`, `/app/upload`, `/app/products`, `/app/leaks`, `/app/calculators`, `/app/scenarios`, `/app/costs`, `/app/shops`, `/app/team`, `/account/info`, `/account/billing`, `/account/data`, `/app/sample`, `/welcome`, `/invite/:token`. Also refresh | You stay on the same page **and the same shop** (the shop is in the URL), still signed in. No flash of the signed-out or Home page. | IA-1, SH-6 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | the cancel confirmation and the import review. | | |
| NAV-12 | P0 | Copy the URL of each signed-in page, open it in a new tab (still signed in), then in a private window (signed out). | In the new tab, the same page opens. Signed out, you are sent to Sign in, and after sign-in you return to the **same deep link**. | V5 |
| NAV-13 | P1 | Back and forward through 10 mixed navigations (public and signed-in). | Each step shows the right page. No loop through the sign-in page, no blank screen and no duplicate history entries. | V5, 15.1 |
| NAV-14 | P1 | Deep link to a page the user's role or plan can't access (a member opens `/billing`, a Starter user opens a Scale-only shop URL, Account A opens Account B's shop ID). | A clear "not available on your plan or role" state, or a redirect. **No data leak.** See SEC. | V5, V15, V16 |
| NAV-15 | P1 | Unknown URL `/does-not-exist`. | A real 404 page (HTTP 404) with the header, footer and a link home. Not the Home page with status 200. | G1 |
| NAV-16 | P2 | URLs with a trailing slash, mixed case and query strings (`?utm_source=x`). | They resolve to the same page, with a canonical URL set. Query parameters survive refresh where the v20 design says they should (for example the plan chosen on Pricing). | V5 |
| NAV-17 | P1 | Stripe return URLs (`success_url` and `cancel_url`), refreshed after returning. | You land on the right signed-in page with a confirmation. Refreshing shows no duplicate "trial started" message and starts no second checkout. | V5, CHK |
| NAV-18 | P1 | Links in emails (verify, reset, reminder → Plan & billing, invite, contact copy). | Each opens the correct deep page on margins365.com, refreshes correctly, and sends you through sign-in when needed. | V5, V21 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| NAV-19 | P2 | Hash or anchor links (the Pricing plans anchor, FAQ entries in the Help centre). | They scroll to the anchor, the URL updates, and refresh returns to that anchor. | V5, V7 |
| NAV-20 | P2 | Two tabs open: sign out in one. | The other tab detects it at its next action and goes to Sign in without showing stale data. | 10.2.2 |
| NAV-21 | P1 | Scroll to the bottom of Home and click each "Start here" button. | The new page opens **at the top**. Focus moves to the main heading (or to a skip target). | V4, G2 |
| NAV-22 | P1 | From the bottom of every page, click each footer link. | The new page opens at the top. | V4 |
| NAV-23 | P1 | From mid-page, click each header nav item and each button that changes page. | The new page opens at the top. | V4 |
| NAV-24 | P1 | Inside the signed-in app, from the bottom of a long Control room tab, switch tab, open Plan & billing, switch shop and open a product. | Each opens at the top (unless the v20 design says a tab switch keeps its position). | V4, V12 |
| NAV-25 | P2 | Back after scrolling: scroll Pricing halfway, open Help centre, press Back. | The browser restores your previous position on Pricing (normal browser behaviour). A new navigation always starts at the top. | V4 |
| NAV-26 | P2 | Screen reader: after each route change, check what is announced. | The new page title or heading is announced, and focus isn't left on a control that has disappeared. | WCAG 2.4.3, 4.1.3 |
| NAV-27 | P2 | Phone and iPad: repeat NAV-21–NAV-23. | The page heading isn't hidden under the sticky header (there is no banner, K81). | 15.3, K81 |
| NAV-30 | P1 | **How intuitive it is (task-based).** Recruit 5 people who haven't seen the product (or the QA team members least familiar with it). Give each one the tasks in the next row without hints. Record time, clicks, wrong turns and their own ease rating | Targets per task: ≥ 4 of 5 people succeed. Median clicks and time are at or under the target in NAV-31. Average ease ≥ 4. Any task that misses its | V13, 15.2 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | from 1 to 5. | target is a **P1 defect** (UX), with a recording as evidence. | |
| NAV-31 | P1 | Tasks (signed in where needed), with target clicks and time: (1) Find the Control room from Home: 1 click, 10 s. (2) Switch to your second shop (Scale): 2 clicks, 15 s. (3) Add a third shop: 4 clicks, 60 s. (4) Invite a bookkeeper to a seat: 4 clicks, 60 s. (5) Remove that member: 3 clicks, 30 s. (6) Change your business phone number: 3 clicks, 45 s. (7) Find out when you'll next be charged and how much: 2 clicks, 20 s. (8) Cancel your subscription: 3 clicks, 45 s, with the reason optional. (9) Download your data: 3 clicks, 30 s. (10) Contact support: 2 clicks, 90 s including typing. (11) Find the Terms before signing up: 1 click, 10 s. (12) Find the hard order limit of your plan: 2 clicks, 20 s. (13) Upload a Shopify Orders CSV: 3 clicks, 60 s. (14) See the top-ranked leak and its £ impact: 1 click, 10 s. | Record the actual results. Any task that needs more than 2× the target clicks, or that needs help from the moderator, fails. | V12, V13, V16, V19, V8, 15.2 |
| NAV-32 | P2 | Labels and wording audit: in the signed-in app, list every navigation label and section name. | They are consistent (for example "Control room" in one form only, "Plan & billing" in one form only). Sentence case, plain English, and no jargon without help text. | 22.11 |
| NAV-33 | P0 | **iPhone Safari:** scroll to the very bottom of Home. Tap each Start here button, each footer link and each header item (go back to the bottom of Home each time). Record a screen video. | Each new page appears **at the very top, instantly, with no visible scrolling animation**, and is still at the top 2 seconds later. (Live today: smooth scrolling makes the page animate up from the old position, and on iPhone it can stop near the bottom, G16.) | K82, NV-1 |
| NAV-34 | P1 | Repeat NAV-33 from the bottom of every public page and from long signed-in screens, on Android Chrome, iPad and desktop. Include email links, the | Same result every time. | K82, NV-2 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | redirect after sign-in and Stripe returns. | | |
| NAV-35 | P1 | Throttle the network to a slow 3G profile and repeat NAV-33. | After landing at the top, late-loading sections, images and fonts don't push the view down. The heading isn't hidden under the sticky header. | K82 |
| NAV-36 | P2 | In-page jumps (Compare plans on Pricing, Control room section links), then Back. | In-page jumps still scroll to their target. Back restores the earlier position. | K82, NV-3, NV-4 |

### Suite AUTH — Sign-up, verification, sign-in, sessions and password reset

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| AUTH-01 | P0 | Sign up with email and password, including the consent checkbox (suite LEG). | The account is created and a verification email arrives (EML-01). Uploads and checkout stay locked until you verify. | 5, 10.2.1 |
| AUTH-02 | P1 | Password rules: try 14 characters, 15 characters, a 64-character passphrase, a known breached password (for example `password123456789`), and only spaces. | Below 15 is rejected. 15+ is accepted with no rules about character types. Breached passwords are blocked with a clear message. Errors are accessible. | 5 |
| AUTH-03 | P0 | Verification link: use it once, use it again, use it after 24 hours (test clock) and change one character. | The first use verifies. Later uses show a clear "already used or expired" message with a resend option. A tampered link fails safely. | 22.8 |
| AUTH-04 | P0 | Continue with Google (shown first): a new account, a returning account, and an account where `email_verified=false`. | New and returning accounts sign in. An unverified Google email is not treated as verified. Profile completion (business name and the rest) is asked for before first use (V18). | 5, 16.5, K57 |
| AUTH-05 | P0 | Link Google to an existing email account with the same verified email. Also try a *different* Google email. | The link only works with a matching verified email, under the anti-takeover rules. A different email doesn't silently join the accounts. | 16.5 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| AUTH-06 | P1 | In-app browser (Instagram or Facebook): tap Continue with Google. | A clear prompt to open the page in Safari or Chrome. Email sign-in still works. | 15.1 |
| AUTH-07 | P0 | Sign in with the wrong password 10+ times, from one IP and then from several. | Rate-limited, with a neutral message that doesn't reveal whether the account exists. No lockout of a real user without a recovery path. | 16.5 |
| AUTH-08 | P0 | Session cookie: inspect it in devtools. | HttpOnly, Secure, SameSite (Lax or Strict), scoped to margins365.com, no token in localStorage. Expiry set as the v20 design says. | 10.2.2, G7 |
| AUTH-09 | P1 | Session expiry: idle past the session lifetime, then click an action. | Sent to Sign in, then returned to the same page. No data shown after expiry, and no half-saved changes. | V5 |
| AUTH-10 | P0 | Sign out, then press Back. | No signed-in content is shown from cache. Cache-Control on signed-in responses prevents it. | SEC |
| AUTH-11 | P0 | Sign out of all devices (Profile & sign-in): sign in on 2 browsers, then use it on one. | The other browser is signed out at its next request. | 5, 10.2.2 |
| AUTH-12 | P1 | Forgot password? appears under the password field. | Present and quiet (not a competing primary). | S65 |
| AUTH-13 | P0 | Reset request for an unknown email, a Google-only account and a password account. | Exactly the same on-screen message: "If an account exists, we've sent a reset link." The same response time (within normal variation) and the same API response. | S66 |
| AUTH-14 | P0 | Reset email for a password account. | Subject "Reset your Margins365 password", a Reset password button, "This link expires in 60 minutes and can be used only once.", and the ignore line. Sent through SES eu-north-1. No mention of cancelling. Link on margins365.com. | S67, V1, V21 |
| AUTH-15 | P0 | Reset link at 59 minutes, at 61 minutes, a second use, an older link after a newer request, and a | The 59-minute link works. The others show a clear error and "Send a new link". | S68, S69 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | tampered token. | | |
| AUTH-16 | P0 | Reset rate limits: 4 requests for one email, and 11 from one IP, inside 60 minutes. | "Please wait before requesting another link". Account existence isn't revealed. | Q34 |
| AUTH-17 | P1 | Google-only account reset email. | Subject "Your Margins365 sign-in". Tells you to use Continue with Google. No set-password link. | S70 |
| AUTH-18 | P0 | After a successful reset. | The new password works and the old one fails. Every other session is signed out. The "Your password was changed" email arrives. | S71 |
| AUTH-19 | P1 | Reset journey on a phone and an iPad. | Meets the K48 type sizes and 44 px targets. No pinch-zoom. | S72 |
| AUTH-20 | P1 | Sign-up validation: invalid email, an existing email, and a very long email (254 and 255 characters). | Clear accessible errors that keep what you typed. Signing up with an existing email doesn't reveal it beyond the approved neutral message. | 16.5 |
| AUTH-21 | P0 | **End-to-end reset** for a real test password account, on iPhone Safari, Android Chrome and desktop. Open the link on a different device from the one that asked for it. | The email arrives. The link opens the reset page, and the new password works while the old one fails. Other sessions are signed out, and "Your password was changed" arrives. | K85, PR-1 |
| AUTH-22 | P0 | Block the server (devtools offline, or block `/api/*`). Then try sign in, Continue with Google, Forgot password, Set new password and profile save. | Each shows "We couldn't reach Margins365. Check your connection and try again." Nothing appears signed in, and no reset or verify token is stored in the browser (no `marginos.resetTokens` or `marginos.verifyTokens`). (Live today: demo fallbacks show success, G18.) | K85, PR-2 |
| AUTH-23 | P0 | With an HTTP client, send a reset request for a test account with `origin` set to `https://evil.example` (and a forged Origin header). | The reset email's link is on `https://margins365.com`. The forged value is ignored. | K85, PR-3 |
| AUTH- | P1 | Open `/reset-password` from a reset | The page loads (200, not 404) and survives a | K85, |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| 24 | | email, refresh it, and check the address bar and network requests. | refresh. The token is removed from the address bar, and no analytics or third-party request carries it. | PR-4 |
| AUTH-25 | P0 | Staging: make SES fail, then request resets for an existing account and an unknown email. | Both show the identical neutral message, with similar timing. An alert is raised, and the email arrives after the retry once SES works again. | K85, PR-5 |

### Suite CHK — Checkout, Stripe, trial, conversion, plan changes and payment failure

Use Stripe test mode and test clocks. Check every result in **three places**: the app UI, the Stripe dashboard and the app's entitlement record (admin).

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| CHK-01 | P0 | For each of the **8 combinations** (4 tiers × monthly/annual), start a trial from Pricing. | Stripe Checkout opens in subscription mode with Managed Payments, a card is collected, and **£0.00 is charged today**. The trial is 14 days. The entitlement records the chosen plan and interval, trial start and end, the first charge date and amount, and the founding status. | 7, 12.5, S17, S18 |
| CHK-02 | P0 | Checkout wording for each tier (after V17), before you submit the card. | The pricing card reads "14 days free, then £[price] a month including VAT. You won't be charged until [date]. Cancel any time before then in one click." Checkout states your 14-day free trial **of the plan you chose**, that a card is collected, that you pay nothing today, the exact amount and date of the automatic charge, and that you cancel in one click in Plan & billing. **No** "You'll try Pro" and **no** "not the Pro price". The date and amount use the account's time zone and name it. | 12.5A, V17, S23 |
| CHK-03 | P0 | Verification gate: an unverified account tries to check out. | Blocked, with a "Verify your email" prompt. | 10.2.1 |
| CHK-04 | P0 | Second trial on the same account (cancel, then try again before the account closes); a new account | A second trial on the same account is refused and a paid option is offered. Same card: refused where Stripe supports | S21, S22 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | using the same card. | the check, and no card data is shown. | |
| CHK-05 | P0 | Double-click "Start trial" and open Checkout in two tabs. | Only one subscription is created. The second tab shows a clear "you already have a trial" message. | 12.5, 12.10 |
| CHK-06 | P0 | 3-D Secure card, declined card and insufficient-funds card at Checkout. | The 3-D Secure challenge works. A declined card shows Stripe's error. No trial and no partial entitlement is created. | 12.10 |
| CHK-07 | P0 | Trial confirmation email (EML-05). | It states the chosen plan, the amount, the charge date, and cancel in Plan & billing. No email-cancel route. | 12.5, 12.5A |
| CHK-08 | P0 | **Reminder:** advance the test clock to 3 days before the trial ends. | Exactly one reminder. Subject like "Reminder: your Growth trial ends on [date] — you'll be charged £[amount] unless you cancel". The body has the chosen plan, amount, date and a link that opens Plan & billing. No list of Pro features that will lock and no Keep Pro (V17). It doesn't ask you to reply or email to cancel. | 12.5A, S20, S30, V17 |
| CHK-09 | P0 | **Day 15 conversion** for each tier and interval. | The charge is exactly the displayed chosen-plan amount (with the founding 50% if eligible, see OFF), charged once. Status becomes active. The entitlement and limits stay the same as during the trial, because the trial was already the chosen tier (V17). A receipt arrives. | 10.2.8, S39 (updated) |
| CHK-10 | P0 | Cancel during the trial (CAN suite), then advance past day 15. | **No charge, ever.** Access continues until the original trial end, then the account is closed. | S19, S25, D2 |
| CHK-11 | P0 | Late or replayed webhooks: replay `customer.subscription.updated`, `invoice.paid` and `trial_will_end` out of order after a cancellation. | The latest Stripe state wins. A cancelled trial is never charged or revived. Each event is processed once. | 12.10, S15, S25 |
| CHK- | P0 | Webhook signature: send a forged | Rejected (400), with no change to state. | 12.6 security |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| 12 | | webhook with no signature or a bad one. | | |
| CHK-13 | P0 | Upgrade mid-period (Starter→Growth, Growth→Scale), monthly and annual. | Takes effect immediately after Stripe confirms the prorated charge. The new limits apply. Current usage is kept. The proration amount shown before you confirm matches the invoice. | S4, 12.4 |
| CHK-14 | P0 | Change plan **during a trial**: upgrade from Starter to Pro, and downgrade from Pro to Growth while usage is above the Growth limit. | Takes effect straight away for features and limits. The original trial end date stays. No new trial and nothing charged today. The day-15 amount updates everywhere (Plan & billing, the banner, the reminder). After a downgrade below current usage, new uploads are blocked as in 12.4. | 12.5B, TR-3, PB-3 |
| CHK-15 | P0 | Downgrade (Scale→Starter). | Scheduled for the next renewal. Clearly shows the date and what will change (shops, seats, history, platforms). No silent deletion. Extras lock at renewal (Q27) and their data is kept. | S5, Q27 |
| CHK-16 | P1 | Switch monthly to annual and annual to monthly. | Takes effect at renewal, unless Stripe confirms an immediate prorated switch. Shown clearly before you confirm. | 12.5 |
| CHK-17 | P0 | Annual Pro paid. | £1,290 (or the founding annual amount under the v20 rule) is charged once. 12 months of access. The order usage counter **resets monthly**. | S2, L10 |
| CHK-18 | P0 | Failed renewal (test card 0341): advance through the retries. | Up to 14 days of retries with access kept. A persistent banner, an update-card route, and emails warning that final failure ends access and wipes the data, with an export offered. | S7 |
| CHK-19 | P0 | Card recovered during the retries. | Becomes active again with no duplicate subscription and no data lost. | S8 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| CHK-20 | P0 | Final failure. | Access ends, the data is wiped immediately, and the deletion confirmation email is sent. | S9, D4 |
| CHK-21 | P0 | First-payment refund requested within 14 days, **including when that payment was the trial conversion** (OD7 resolved by K74). | A full refund, once per customer. Access ends immediately, the data is wiped, and a founding place (if held) is released. A second refund request is refused. Day 15 or later after the first payment: no contractual refund, and statutory rights are unaffected. | S10, S11, Refunds v20, 12.5C |
| CHK-22 | P1 | Dispute created and lost (Stripe test dispute). | Follows 12.5: a lost dispute ends the subscription and the data is wiped at access end. | 12.5 |
| CHK-23 | P1 | Customer portal from Plan & billing: update card, view invoices, download an invoice PDF. | Works, with a return URL to margins365.com Plan & billing (V21). Invoices show Margins365. | 12.10, V1 |
| CHK-24 | P0 | Cancellation outside the product (Link's or Stripe's own subscription tools). | The webhook treats it like an in-app cancellation: closure and deletion are scheduled for the period end, and the same confirmation email is sent. No half state. | CA-4, 23.10 |
| CHK-25 | P0 | VAT-inclusive prices: inspect the Stripe price objects and invoices. | Tax behaviour is inclusive. The invoice total equals the published price exactly. VAT is shown as the accountant has approved. | 3, 12.9 |
| CHK-26 | P0 | Tamper: change the price ID, plan or quantity in the checkout request (devtools or a proxy). | The server ignores client-supplied prices and plan state, or rejects them. You can't get Scale at the Starter price, a longer trial or an unearned discount. | 12.5 entitlement, SEC |
| CHK-27 | P0 | Daily reconciliation job: make Stripe and the app disagree in staging (change Stripe directly). | Reconciliation detects it and alerts. No secrets in the alert. | 12.10 |
| CHK-28 | P1 | Legacy lifetime account. | Permanent access, no subscription charge, no trial button and no Cancel | S16, D11 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | subscription button. A refunded or lost-dispute legacy licence has no access. | |
| CHK-29 | P1 | Stripe return URLs and success/cancel pages. | They are on margins365.com, with no marginos.online. Cancel returns you to Pricing with your choice kept. | V21, 20.5 |
| CHK-30 | P0 | A subscription that has ended: inspect the entitlement. | The state is ended or closed. **Not "free"**: there is no Free plan. | G9, 7 |
| CHK-40 | P0 | **Live mode, run by Akthar or with his written go-ahead only:** a real trial, cancelled straight away. | No charge. The dated closure email arrives. | 12.10 live proof |
| CHK-41 | P0 | **Live mode:** a real trial converted on day 15 (a low-cost tier). | The exact amount is charged once, and the reminder was received 3 days before. The statement descriptor is recorded. | 12.10 |
| CHK-42 | P0 | **Live mode:** a first-payment refund, followed by deletion. | Refunded. Data wiped. Login removed. | 12.10 |

### Suite OFF — Founding offer: 50% off for 6 months, first 100 paying accounts (V20, K72, 12.5C, FO-1–FO-7)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| OFF-01 | P0 | With places left, view Pricing and Checkout for every tier and interval. | The line "Founding offer: 50% off your first 6 months — for the first 100 paying customers. [n] places left." is shown. Checkout shows the exact founding amount, the number of founding payments, and the normal price afterwards: monthly £19.50 / £39.50 / £64.50 / £99.50 then £39 / £79 / £129 / £199; annual £292.50 / £592.50 / £967.50 / £1,492.50 then £390 / £790 / £1,290 / £1,990. All including VAT. | 12.5C, FO |
| OFF-02 | P0 | Monthly founding account: convert on day 15, then advance the test clock month by month. | Payments **1–6** are exactly 50%. Payment **7** is the full price. In Stripe, a 50% coupon lasts 6 invoices and was applied on the server. | 12.5C, S87 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| OFF-03 | P0 | Annual founding account. | The first annual payment is 75% of the full price (25% off), charged once. The renewal is the full annual price. | 12.5C, S87 |
| OFF-04 | P0 | Place lifecycle: start a trial (reserved), cancel it (released); start another (reserved), convert (confirmed); refund the first payment (released); let the first payment finally fail (released). Watch the server count at every step. | "[n] places left" = 100 − reserved − confirmed, and it updates at each step. Released places go back into the pool. | 12.5C |
| OFF-05 | P0 | **Boundary:** seed reserved + confirmed = 99. Start trial A (takes the 100th place), then trial B. | A gets the founding price. B's Pricing and Checkout show **no** offer and the **full price**, and B is charged the full price. The offer line disappears everywhere when the count reaches 0. | 12.5C |
| OFF-06 | P0 | **Race:** with 1 place left, open two Checkouts at the same moment (a script or two testers). | Exactly one place is reserved. Reserved + confirmed never goes above 100. The other customer sees the full price **before** submitting a card. | 12.5C, FO |
| OFF-07 | P0 | Honest display: compare "[n] places left" with the server count. | They are equal. No timers, no invented scarcity, no reset. | 12.5C, DMCC Act 2024 |
| OFF-08 | P0 | After a released place is taken again, and after a founding account closes and the same person signs up again. | The place can go to someone else, but **never back to the same person** after their account closes. | 12.5C |
| OFF-09 | P0 | Plan change during the founding period: upgrade from Starter to Pro after founding payment 2. | 50% applies to the new plan for payments 3–6. Shown before confirming. Matches the Stripe invoice. | 12.5C |
| OFF-10 | P0 | Switch from monthly to annual: (a) before any founding payment; (b) after founding payment 1. | (a) The annual first year at 25% off. (b) The remaining discount ends at the switch, and this is shown before confirming. | 12.5C |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| OFF-11 | P0 | Tamper: send a coupon, promotion code or price ID in the checkout request; replay another account's session. | Rejected. Only the server applies the founding coupon, and only to an account holding a place. | 12.5C, SEC |
| OFF-12 | P0 | Where the founding facts are disclosed: Checkout, the trial-started email, Plan & billing, the trial reminder, invoices and the in-app trial banner ("£[founding amount] a month for 6 months, then £[normal amount]"). | Each shows the founding amount, how many founding payments remain and the normal price after them. | 12.5C, 12.5B |
| OFF-13 | P0 | "Founding price ends soon" email. | Sent **14 days before** the first full-price payment, with the date, the new amount and a link to Plan & billing. Sent once. | 12.5C, 23.12 |
| OFF-14 | P1 | Terms and Refunds pages. | Describe the offer exactly as 12.5C does. | K74 |
| OFF-15 | P1 | Admin view of places and the retention of founding records after an account closes. | Accurate. After closure only a count with no personal data is kept. | 23.13 |
| OFF-16 | P1 | Old price settings (`foundingMonthlyGbp` = the full price, G11). | They are replaced by the 12.5C amounts or removed, so no display shows a wrong founding price. | G11 |
| OFF-17 | P0 | **Pence shown:** plans pop-up tiles, the trial terms, Pricing cards, Checkout, Plan & billing and the trial email, monthly and annual, while founding places remain. | £19.50, £39.50, £64.50 and £99.50 a month; £292.50, £592.50, £967.50 and £1,492.50 a year. Never rounded (live today: £20, £40, £65 and £100). The trial terms state the exact amount charged (for example "we will automatically charge £39.50 including VAT" for Growth), and it equals the Stripe amount. | K72, 12.5C, D-1 |

### Suite TRL — Trial = the tier you choose (V17, reverses K52)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| TRL-01 | P0 | Start a **Starter** trial. | Starter features only: 1 platform slot, 3 months of history, 1 seat, 1 shop, the simple | V17, 3, 8 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | UK VAT toggle, no overheads, no per-channel ROAS, no own FX rate, no saved scenarios, no PDF. The order limit is **500**. | |
| TRL-02 | P0 | **Growth** trial. | Growth features: up to 2 platforms, 12 months of history, 2 saved scenarios, PDF, overheads, per-channel ROAS, own FX, full tax. Limit **2,000**. 1 seat. | V17 |
| TRL-03 | P0 | **Pro** trial. | Pro features, a limit of **5,000**, 2 seats. | V17 |
| TRL-04 | P0 | **Scale** trial. | Scale features, a limit of **15,000**, 3 shops, 5 seats. | V17 |
| TRL-05 | P0 | The entitlement record during a trial. | The trial entitlement equals the chosen plan (or the field has been removed, per the v20 design). The UI never gives more than the chosen tier. | V17, 12.5 |
| TRL-06 | P0 | Search the app and emails for retired reverse-trial items: "Keep Pro", "You're trying Pro", the Pro label on a non-Pro trial, "features that will lock", and "Every trial includes Pro features". | None found. | V17 |
| TRL-07 | P1 | In-app trial banner, for each tier, with and without a founding place. | "You're on your [Plan] free trial until [date]. Your first payment of £[amount] is on [date]. Cancel any time in Plan & billing." Founding accounts add "£[founding amount] a month for 6 months, then £[full amount]." There is a plan badge in the account menu and Plan & billing. No Keep Pro. | 12.5B, 23.9 |
| TRL-08 | P0 | Conversion: features before and after day 15. | Nothing locks and nothing changes at conversion, because the tier is the same. No data is wiped. | V17, D13 (updated) |
| TRL-09 | P0 | Starter trial: try to upload the 501st unique order. | Blocked, with the standard overage message. (This replaces L17: overrun after conversion no longer arises from a Pro trial.) | V17, 12.4 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| TRL-10 | P1 | Sample data during a trial. | Labelled sample data. It never counts toward the allowance. | 7, 17.1 |

### Suite LIM — Hard monthly order limits and platform slots

Run each L-test on the tier named. Then repeat L1–L4 on Growth (1,999/2,000/2,001), Pro (4,999/5,000/5,001) and Scale (14,999/15,000/15,001).

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| LIM-01 | P0 | L1: Starter, 0 used, upload 500 distinct orders. | Allowed. Usage 500. | L1 |
| LIM-02 | P0 | L2: Starter, 499 used, upload 1 new order. | Allowed. Usage 500. The 80% warning was sent at 400. | L2 |
| LIM-03 | P0 | L3: Starter, 500 used, upload 1 new order. | Blocked. new_unique 1, projected 501, overage 1. **No rows committed.** | L3 |
| LIM-04 | P0 | L4: Starter, 450 used, upload 100 new orders. | Blocked in full: projected 550, overage 50. Usage stays 450 and the previous results are exactly the same. The message reads "This file would add 100 new orders, taking you to 550 of 500 orders this billing month, 50 over your limit. Upgrade to Growth to import it. Your existing results are unchanged." Upgrade and Cancel are offered. | L4, 12.4 |
| LIM-05 | P0 | L5: 100 rows that are 50 orders × 2 lines (450 used). | Allowed. Usage 500. | L5 |
| LIM-06 | P0 | L6: Growth, 1,500 used, upload 600 of which 100 already exist. | 500 new. Projected 2,000. Allowed. | L6 |
| LIM-07 | P0 | L7: repeat the same import. | No extra usage. A duplicate/reconciliation result. | L7 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| LIM-08 | P0 | L8: two concurrent uploads that together exceed what's left (two tabs, two seats, or two Scale shops). | Only what fits is committed, by transaction or lock. Usage never goes above L. **This must be enforced on the server** (G7). | L8 |
| LIM-09 | P0 | L9/L10: the monthly boundary, and the annual plan's monthly boundary (test clock). | The old period keeps its set. The new period starts at 0. | L9, L10 |
| LIM-10 | P0 | L11: Starter at 399, import to reach 400. | An in-app notice plus **one** email naming Growth and 2,000 orders. A repeat import sends no second email. | L11, EML-09 |
| LIM-11 | P0 | L12: a fully duplicate upload at the limit. | Allowed to reconcile. Usage unchanged. No false overage. | L12 |
| LIM-12 | P0 | L13: an all-invalid file that looks over the limit. | Nothing imported. The raw file is deleted. No usage added. | L13 |
| LIM-13 | P0 | L14: Starter blocked at 550, upgrades to Growth. | After proration the limit is 2,000 immediately. Re-uploading succeeds. | L14 |
| LIM-14 | P0 | L15/L16: a blocked import on Pro or Scale; an expired or cancelled subscription. | Results, exports and datasets stay visible, with no partial rows. Cancelled: uploads are blocked and export is available until access end. | L15, L16 |
| LIM-15 | P0 | **Account-wide limit:** Scale with shop 1 at 10,000, shop 2 at 4,000, and shop 3 uploading 1,500 new orders. | Blocked: projected 15,500 counted across the **whole account**. The message names the shop, the overage and Upgrade (owner) or "Ask the account owner to upgrade" (member). | SH-4, UP-2, UP-3 |
| LIM-16 | P0 | Scale: the same order ID on two different shops. | Counted as 2 orders (distinct shops or platforms are distinct). The same order uploaded twice to one shop is counted once. | 12.7, V15 |
| LIM-17 | P1 | The usage counter. | "[used] of [limit] orders this billing month" in the Control room status strip, neutral colour, counted across the whole account. | 23.6, 22.9 |
| LIM-18 | P1 | Start fresh, Clear sample data, a time-zone change | **Not reset.** | 17.4.3 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | and a re-upload: then check usage. | | |
| LIM-19 | P0 | Platform slots: Starter tries to add a 2nd platform, and Growth a 3rd. | Refused, with an upgrade prompt naming the plan that allows it. TikTok isn't selectable and is shown as "Excel import coming soon". Pro and Scale: all 3. | 3, Q32, K53 |
| LIM-20 | P0 | Scale platform allowance **per shop**: shop 1 Shopify, shop 2 Amazon and Etsy, shop 3 all 3. | All allowed, because each shop has its own allowance. | 12.7, V15 |
| LIM-21 | P1 | History windows: upload data covering 30 months on each tier. | Starter shows 3 months, Growth 12, Pro 24, Scale all. Older rows are hidden (not deleted), with an upgrade prompt. Upgrading restores them immediately. | 12.4 |
| LIM-22 | P1 | Fair use: Scale with 500,000 stored orders. | The fair-use rule from 12.4 applies, with a clear message. The monthly limit still applies. | 12.4 |

### Suite IMP — Upload and import (Shopify, Amazon, Etsy)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| IMP-01 | P0 | Upload a valid Shopify Orders CSV, then the same file with the optional Payments transactions CSV. | The first imports with fees labelled **estimated**. With the Payments CSV, payment fees are **actual**. The import review appears before results. | 6, 16.1 |
| IMP-02 | P0 | Amazon Custom Unified Transaction CSV (UK, US and German headers). | The header row is found below the description lines. Translated headers are mapped. Transfer rows are skipped. FBA rows are treated as fulfilment fees. Posting dates are used. | 16.1 |
| IMP-03 | P0 | Etsy: Orders CSV only; Order Items only; both; both plus the Monthly Statement. | Either single file fails, naming the missing required file. Both succeed. With the Statement, the actual card-processing fees are used. "--" is read as empty, not zero. | 6, 16.1 |
| IMP- | P0 | A required column missing; columns | A missing required column fails, | 16.1 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| 04 | | reordered; extra columns; a UTF-8 BOM; header case and spacing changed (for example "Lineitem sku"). | naming the column. Reordered, extra, BOM and case variants import correctly. | |
| IMP-05 | P0 | Wrong format: `.xlsx` renamed `.csv`, a PDF, an `.exe` renamed `.csv`, an empty file, headers only, corrupt encoding. | A clear plain-English rejection. Nothing imported. Raw file deleted. No usage added. Previous results unchanged. | 6, 18 |
| IMP-06 | P1 | Mixed valid and invalid rows. | Valid rows import. Invalid rows are listed with their row number and reason. All-invalid imports nothing. | 6 |
| IMP-07 | P1 | Locale formats: EU decimal commas, currency symbols, thousands separators, and the date formats in 16.1. | Parsed correctly. Spot-check 10 rows against the source file. | 16.1 |
| IMP-08 | P0 | Size limits: 100 MB and 100.01 MB; 50,000 rows and 50,001 rows. | At the limit it is accepted. Over the limit it is rejected **before parsing**, with a message naming the limit. No browser crash on an iPad or a mid-range Android phone. | Q10 |
| IMP-09 | P0 | **Removing personal data:** import the file seeded with markers (`QA-PII-*`). Then search the cleaned rows, the import preview, errors, exports (Download my data), the PDF, server logs, error reports, browser storage, the network responses and support tooling. | **Zero** markers found anywhere. Country and the permitted US, Canadian and Australian region are kept. | 6, 10.2.3 |
| IMP-10 | P0 | Raw files deleted: after a success, a failure, a cancellation, and an import left unfinished for 61 minutes (then run the 15-minute job). | The original file is gone from all storage. It is never in exports, logs or backups. | 6, 10.2.4, 19.4.2 |
| IMP-11 | P0 | Duplicates and merging: re-upload the same file; overlapping files; a refund-only row for an existing order. | Identical rows are skipped and changed rows updated. A refund links to its original order. No double counting. Usage counts canonical orders. | 12.7 |
| IMP-12 | P0 | The first real upload clears sample data. Also try a failed, a blocked and a template-only | A successful real order upload removes every sample row, label | 17.1, |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | upload first. | and cost in the same step. Failed, blocked and template-only uploads leave the sample data as it was. | Q11 |
| IMP-13 | P0 | CSV injection: product names starting with `=`, `+`, `-` or `@`, and HTML or script in names. | Shown as text in the app. In Download my data, the cells are escaped so a spreadsheet won't run them. | SEC |
| IMP-14 | P1 | Cost template CSV and manual cost entry: valid, invalid decimals, a negative cost, a missing SKU, the wrong currency. | Validated row by row. Overheads only on Growth and above. | 6 |
| IMP-15 | P1 | Ad spend entries with date ranges that partly overlap the period. | Pro-rated by overlapping days, shown in Show the maths. | 12.0 |
| IMP-16 | P1 | Currency: orders in EUR or USD with an ECB rate; a currency with no ECB rate on Starter compared with Growth. | Converted with the ECB rate. Starter excludes the orders with no rate and shows the count and total. Growth and above can enter a "user rate". | 6 |
| IMP-17 | P1 | Scale: upload to shop 2 while shop 1 is selected in another tab. | The upload goes to the shop shown on the upload screen. The shop is named on the confirmation. There is no way to upload to the wrong shop by accident. | V15 |
| IMP-18 | P1 | TikTok on the upload screen. | No TikTok option or file type works. "TikTok Shop UK (Beta): Excel import coming soon" is shown. | K53, S47 |
| IMP-19 | P2 | Upload on a phone (from Files, iCloud or Google Drive) and on an iPad. | Works, with progress shown. Cancelling works. Leaving the page mid-upload asks you to confirm. | 15.3 |

### Suite CALC — Calculations, Health Score and the sample shop figures

Business & Product signs off the expected value of each fixture before you run it. Use decimal arithmetic with half-up rounding (12.3). Check every result in the UI, in Show the maths, the PDF and the CSV export.

| ID | P | Fixture | Expected result | Ref |
|---|---|---|---|---|
| CALC-01 | P0 | Net margin 10%, no ads, returns 3%, product mix 0%, actual fees within 1 percentage point of the preset, net shipping 5%. | Ads dropped (not applicable, so confidence isn't lowered). Weights rescaled to 80. Score = (35×50 + 15×100 + 10×100×3) ÷ 80 = **78.125 → 78**, band **Needs attention**. The breakdown says Ad efficiency was dropped and why. | 12.1 |
| CALC-02 | P0 | Every part at its midpoint: net margin 10%, ROAS exactly 1.0× break-even, returns 9%, mix 25%, fees 5.5 points above, shipping 10%. | Each part 50. Score **50**, band **Needs attention** (the lower edge). | 12.1 |
| CALC-03 | P0 | Ad efficiency part at ROAS of 0.75×, 0.875×, 1.0×, 1.25× and 1.5× break-even. | 0, 25, 50, 75 and 100 points. | 12.1 |
| CALC-04 | P0 | A fixture whose unrounded score is 79.5, and one at 49.5. | They round to 80 (**Strong**) and 50 (**Needs attention**). Rounding happens before banding. | 12.1 |
| CALC-05 | P0 | Contribution margin ≤ 0% with ad spend. | Ad efficiency is 0, with "Every ad pound loses money" (in the home currency's name, for example "dollar"). | 12.1 |
| CALC-06 | P0 | Fees presets only, or a mix of actual and preset. | The Fees part is dropped and confidence lowered. Fee drag never fires. | 12.1, 12.3 |
| CALC-07 | P0 | Confidence: a 10-day period, 25 orders, cost missing on 12% of revenue, and a High returns leak using estimated units. | Each lowers confidence by one level (Low at the lowest), and each reason is listed. A warning that the period is under 14 days. | 12.1 |
| CALC-08 | P0 | Store revenue of 0. | No score. You're asked to check the file. | 12.1 |
| CALC-09 | P0 | Product verdicts: net margin 9.95%, 9.94%, a net profit of −£0.004, and costs with no revenue. | Healthy (rounds to 10.0%), Thin (9.9%), Losing money, No revenue. A product whose sales were all refunded shows Losing money. | 12.2 |
| CALC-10 | P0 | Unprofitable ads: ad spend £1,000 and CM £800 (ROAS below 1.0× break- | Impact £200, then £1,000 (the most it can be is the ad spend). Between 1.0× and | 12.3 |

| ID | P | Fixture | Expected result | Ref |
|---|---|---|---|---|
| | | even); then CM −£100. | 1.5× break-even, no leak. | |
| CALC-11 | P0 | High returns: 20 orders, unit return rate 20%, store average excluding this product 5%, return cost £400. | Triggered (above 2× the average). Target rate 5%. Impact £400 × (1 − 5/20) = **£300**. Single-product store: 14% → no leak, 16% → leak with a 15% target. Fewer than 10 orders → no leak. | 12.3 |
| CALC-12 | P0 | Shipping subsidy: net shipping cost £700 on £10,000 of shipping-eligible revenue; then exactly £500. | Impact **£200**, then no leak. FBA orders are left out of both figures. | 12.3 |
| CALC-13 | P0 | Fee drag: compared actual fees 7.5% against a 6.0% preset on £10,000 of compared revenue; then 7.0%. | Impact **£150**, then no leak (exactly 1 point doesn't trigger). | 12.3 |
| CALC-14 | P0 | Thin pricing: target margin 10%, product net margin 6%, revenue £5,000; then set the target to 5%. | Impact **£200**, then no leak. | 12.3 |
| CALC-15 | P0 | Monthly scaling: a 60-day period with a leak of £400 over the period. | Shown as **£200 a month**. Leaks are rounded to whole pounds. No impact is ever negative. **No total of all leaks is shown.** | 12.3 |
| CALC-16 | P0 | v17.1 regression set: a £20.00 target price gives exactly 10.0% net margin with shipping charged; a blended £21.10 gives 10.0% and £21.09 doesn't; a £30 order-level refund gives 0.6 and 0.3 estimated units. | All exact. | 10.3 |
| CALC-17 | P0 | Allocation: £10 shipping charged across lines worth £30 and £10; £10 across three equal lines. | £7.50 / £2.50, and £3.33 / £3.33 / £3.34 (the remainder on the last line), flagged "allocated". | 12.0 |
| CALC-18 | P0 | Break-even: CM 25%; CM 0%. | Break-even ROAS 4.00× and ACOS 25.0%. At 0%, ROAS is "not reachable". | 12.0 |
| CALC-19 | P0 | Target price edge cases: a denominator ≤ 0; a result ≤ 0; already at target; a | "Can't reach the target margin at any price" (naming the cause); 0.01 with the note; "Current price already reaches your | 12.3 |

| ID | P | Fixture | Expected result | Ref |
|---|---|---|---|---|
| | | VAT-inclusive seller; multiple platforms. | target margin (target price £X)"; ×(1+tax), rounded up; the platform mix named in Show the maths. | |
| CALC-20 | P0 | **The sample figures match everywhere:** the Home hero card, the Product-section proof line, the Sample shop page, the signed-in sample shop dashboard, the sample PDF, meta descriptions and any marketing figure. | The **same** Health Score, true profit, net margin and top leak everywhere (Home says £840 a month, true profit £2,691, Health 69; the earlier mismatch was Health 69 against 36 and margin 14.2% against 12.4%). Every place is labelled "Sample data". | 17.6, G11 |
| CALC-21 | P0 | Recalculate the sample shop by hand (or in a spreadsheet) from the sample dataset. | The displayed values equal the formula results. If the dataset has changed, the Home proof number has been updated to match. | 17.6 |
| CALC-22 | P1 | Show the maths on every figure. | It opens with a tap or keyboard, shows the inputs, the formula, "allocated" and "estimated" labels, and the stated assumptions (ad spend per unit held, units sold unchanged in scenarios). | 12.0–12.3 |
| CALC-23 | P1 | Scenarios (Growth and above): change price only; change ad spend; change the return rate. | Units sold stay the same, and ad spend per unit is held when only the price changes. A product priced at its target shows exactly the target margin. | 12.3 |
| CALC-24 | P1 | Scale "All shops" view. | Money figures (true profit, revenue, leak £) are shown per shop and in total, and the totals equal the sum of the shops. The **Health Score is not combined or averaged**: it stays per shop. | 23.2 |

### Suite CR — Control room (the signed-in workspace) and plan gating

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| CR-01 | P0 | First results after an upload. | Leads with the highest-£ ranked fix and the top three leaks, then the Health Score, products and detail. | 10.1.5, 15.2.4 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | The same order on a phone. | |
| CR-02 | P0 | Every tier: check what each tier gets against the 3.1 matrix. Yes on all: true profit, Health Score with full breakdown, verdicts, all six leaks with £ impact, ranked fixes, Show the maths, SKU charts, price and target calculator, break-even ROAS and ACOS, Download my data. Growth and above: per-channel ROAS, overheads, own FX, full tax, PDF, scenarios (Growth 2 saved, Pro and Scale unlimited). Starter: simple UK VAT toggle. | Exact match. No blurred data and no locked placeholders. A gated feature shows one contextual upgrade prompt that names the plan. | 3.1, 8, 10.1.6–7 |
| CR-03 | P0 | Gating is enforced on the server: call a Growth-only feature's API (PDF, scenarios save, overheads) from a Starter account. | Refused (403), however the UI is changed. | 12.5, SEC |
| CR-04 | P1 | PDF report (Growth, Pro, Scale). | Beside the results, not in the header. A4, always light, Margins365 lock-up, "x of y" footer, verdicts readable in black and white. No PDF icon anywhere on Starter. | 8, 22.8, K27 |
| CR-05 | P1 | Growth: save a 3rd scenario. | Refused, with an upgrade prompt. Comparisons are unlimited. | 3.1 |
| CR-06 | P1 | Suggest a feature: submit, then submit 1,001 characters. | Saved with timestamp, account, plan, submitter and text, **and emailed to info.marginos@gmail.com** (HELP-17). Thank-you message with no promise of a reply. A limit of 1,000 characters. Admin can see it. | Q33, S58, K83 |
| CR-07 | P1 | Clear sample data. | Only offered while sample data exists. The confirmation names what is removed. Cancel is the default. Your own data is untouched. | 17.2 |
| CR-08 | P0 | Start fresh: Cancel, Escape and Back; then confirm. | Cancel changes nothing. Confirm removes datasets, costs, ads, overheads, scenarios and samples, | 17.3, 17.4, |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | and **keeps** the account, subscription, billing, shops, team and settings. Usage isn't reset. The confirmation shows the real counts and "This can't be undone". | S14 |
| CR-09 | P1 | Light only. | No dark-mode toggle or dark theme. The header has no PDF icon. | K26, 22.12 |
| CR-10 | P1 | Brand colour rules: buttons against Healthy and Strong chips. | They follow K21: a solid teal button with a verb label, and a tinted green chip with a word and ✓, not interactive. Colour is never the only signal. | 22.2–22.4 |
| CR-11 | P2 | Empty states: a new account with no upload; a shop with no data; a product with no costs. | A helpful next step (for example Upload your first file), never a blank panel. "Cost missing" warnings. | 15.2 |

### Suite SHOP — Shops and multi-shop (V15, V12, 23.2, SH-1–SH-7)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| SHOP-01 | P0 | First-run: add the first shop (name and platforms within the plan's slots). | Required before you can upload. Created and selected. Its name is shown in the Control room header. | 23.5, 23.2 |
| SHOP-02 | P0 | Starter, Growth and Pro owner: click Add shop; then try to create a shop through the API. | Add shop opens the upgrade explainer "Add up to 3 shops on Scale (£199/mo)." It never creates a second shop. The API refuses (403 or 409). | SH-1 |
| SHOP-03 | P0 | Scale owner: add shops 2 and 3 (from the account menu and from Shops). Then try a 4th. | 2 and 3 are created, each opening empty with its own upload prompt. At 3 shops the button is replaced by "Scale includes up to 3 shops". The API refuses a 4th. | SH-2 |
| SHOP-04 | P0 | Shop names: 0 characters, 1, 60, 61; the same name as another shop; HTML. | 1–60 characters, unique within the account. A duplicate shows an inline error. HTML is shown as text. Renaming takes effect everywhere at once. | 23.2 |
| SHOP- | P0 | Scale switcher in the account | The current shop is ticked. You stay on the same | SH-6, |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| 05 | | menu: switch from Leaks in shop 1 to shop 2. | kind of page (Leaks → Leaks), at the top. The shop is in the URL. Refresh keeps it. Every figure, the upload target, the PDF and the export change to shop 2. | V12 |
| SHOP-06 | P0 | Switch quickly 10 times while an upload runs in another tab. | Data from two shops never mixes. The upload lands in the shop it was started in. | SH-3, UP-1 |
| SHOP-07 | P0 | Separation: check orders, costs, results, exports, the PDF and search in each shop. Also put shop 1's ID in a shop 2 URL. | Data never appears in another shop. Another account's shop ID returns 403 or 404. | SH-3 |
| SHOP-08 | P1 | "All shops" view (Scale). | Read-only. True profit, revenue and leak £ shown per shop side by side and in total. The **Health Score stays per shop** and isn't averaged. The totals add up correctly. | 23.2 |
| SHOP-09 | P0 | Remove a shop (Scale, owner, more than one shop). | The confirmation names the shop, the item counts that will be deleted and "This can't be undone", and the owner must type the shop name. After confirming, the shop's data is deleted (backups within 7 days). Order usage already counted this month is **not** refunded. | SH-5 |
| SHOP-10 | P0 | Try to remove the last shop. Upload while a shop is being removed. Remove the same shop from two tabs. | Not allowed (use Start fresh instead). The upload is refused with a clear message. The second tab sees "This shop has already been removed". | 23.2 |
| SHOP-11 | P0 | Scale downgrades to Pro at renewal with 3 shops: (a) the owner picks the shop that stays active; (b) the owner doesn't choose. | The other shops become **locked** (kept, not visible, no uploads). If no choice is made, the oldest shop stays active. Upgrading unlocks them with their data. Locked shops are deleted only at access end. | SH-7 |
| SHOP-12 | P0 | Members and shops. | Members can view, switch and upload in every shop. They can't add, rename or remove shops (UI and API). | 23.3 |
| SHOP- | P1 | Starter, Growth and Pro: the | There is no switcher. Rename works. | 23.1 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| 13 | | shop name with Rename in the Control room header (owner). | | |
| SHOP-14 | P1 | Phone and iPad: the switcher and Shops screens. | Usable at 320 px, targets at least 44 px, long names shortened. Works with VoiceOver and TalkBack. | 15.3 |

### Suite SEAT — Seats, roles and invites (V16, 23.3, ST-1–ST-7)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| SEAT-01 | P0 | Seats on each tier, counting pending invites. | Starter 1, Growth 1, Pro 2, Scale 5. Seats used = active members (including the owner) + pending invites. Plan & billing shows the seats used. | ST-1 |
| SEAT-02 | P0 | Starter and Growth: open Team and try to invite (UI and API). | Invite is disabled with "Your plan includes 1 seats. Pro includes 2, Scale includes 5." (check the grammar: it should read "1 seat") and an upgrade link. The API refuses. | 23.3 |
| SEAT-03 | P0 | Pro owner: invite one member. | The invite email "[Business name] invited you to Margins365" arrives through SES from margins365.com, with Accept linking to `/invite/:token`. The invitee signs in or signs up with **the same, verified email**. Membership becomes active and they land in the Control room of the current shop. | ST-2, ST-3 |
| SEAT-04 | P0 | Pro: a second invite while one is pending. Scale: a 5th member plus 1 pending invite. | Refused, because the seats are full including the pending invite. | ST-1 |
| SEAT-05 | P0 | Invite link: use it twice; after 7 days (test clock); after it's been revoked; with a different email signed in; tampered. | One use only. Expired or revoked: "This invite is no longer valid. Ask the account owner for a new one." Wrong email: "This | ST-2, 23.3 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | invite is for a different email. Sign out and use [masked email]." Tampered: a safe error. | |
| SEAT-06 | P0 | Invite someone who already belongs to another account; invite an existing member again. | "This person already uses Margins365 with another business." Duplicates are refused. | 23.3 |
| SEAT-07 | P1 | Revoke a pending invite; send a new one. | The seat is freed. The old link no longer works. | 23.3 |
| SEAT-08 | P0 | **Member permissions (23.3 table).** As a member, **allowed**: view everything in every shop; upload and review imports; edit costs, ads and overheads; create scenarios and datasets; download the PDF (on tiers that include it); Download my data; edit your own name, phone, password and Google link. **Refused** (check UI **and** API): add, rename or remove shops; invite, revoke or remove; edit the business name, country, VAT number or address; Plan & billing; Cancel; Start fresh; Clear sample data. | Allowed actions work. Every refused action is hidden or read-only in the UI **and** returns 403 from the API. `/account/billing` shows "Only the account owner can manage billing." Members never see "Cancel subscription". The Team page is read-only for members. | ST-4, ST-7, PB-1 |
| SEAT-09 | P0 | Owner removes a member who is currently signed in. | Their session ends at their next request. They get the email "You no longer have access to [Business name] on Margins365". Their uploads and edits stay with the account. The seat is freed. | ST-5 |
| SEAT-10 | P0 | Downgrade below the current seats at renewal: (a) the owner chooses who stays; (b) no choice. | The others become `locked`: they can't sign in to this account and are told why. With no choice, the most recently added are locked first. Upgrading restores them. Nothing is deleted. | ST-6 |
| SEAT-11 | P0 | The owner cancels the subscription. | Members get the dated warning email. At access end every membership ends, along with the account. | 23.3, K51 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| SEAT-12 | P1 | Identity: a member's header and account menu. | The account button shows the **business name**. The menu shows their own name and email and a **Member** badge. The team list shows each person's name. | 23.1, V14 |
| SEAT-13 | P1 | Ownership transfer. | Not offered. The Help centre explains that the owner keeps control of billing. No partly working option is hidden in the UI or API. | 23.3 |
| SEAT-14 | P1 | Invited member onboarding. | Skips the plan and shop steps and asks only for their own name. | ON-4 |
| SEAT-15 | P1 | Audit events for invite, accept, revoke, remove and lock. | Each is logged with type, time, account ID, the user who did it and the plan. No message bodies. | 23.0 |

### Suite PROF — Info (account profile) and identity (V18, V14, V13, 23.4, IN-1–IN-6)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| PROF-01 | P0 | Sign-up form. | Asks only for email and password (or Continue with Google), plus acceptance of the Terms with a Privacy link. No phone or business fields at sign-up. | IN-1 |
| PROF-02 | P0 | First-run `/welcome`: try to continue with each required field empty. | You can't finish without your name, business name and country. | IN-2 |
| PROF-03 | P0 | Info fields at `/account/info`. | Required: your name, business name, country, email, home currency and time zone (the last two default from the country and browser). Optional: phone, business address, VAT number, website. Optional fields can be left empty. | 23.4, IN-3 |
| PROF-04 | P1 | Validation: names and business names of 0, 1, 100 and 101 characters; phones | Limits are enforced with accessible errors and what you typed is kept. A visible | 23.4 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | as +44, +1 and +61 numbers plus invalid ones; a VAT number of 21 characters; choosing the country by typing; an invalid email. | "Saved" confirmation, and the change survives refresh. | |
| PROF-05 | P0 | Change the email. | It needs verification **before** it takes effect. Until then the old email keeps working. | IN-5 |
| PROF-06 | P0 | Change the business name. | The account button updates straight away, and so do menus, the team list, invites and the PDF. | IN-4, V11 |
| PROF-07 | P0 | As a member: edit the business fields (UI and API). Edit your own name and phone. | Business fields are view-only, and the API returns 403. Your own fields save. | IN-6 |
| PROF-08 | P1 | Sign-in management within Info: password change, link or unlink Google, sign out of all devices. | All work. There is no Delete account control anywhere. | 5, K29 |
| PROF-09 | P1 | Settings sections. | Info (which replaces "Profile & sign-in"), Plan & billing and Data & privacy, all reachable from the account menu. | 23.1 |
| PROF-10 | P0 | Download my data contains the profile. After closure the profile is deleted. | Yes to both. | 12.6, 23.13 |
| PROF-11 | P1 | Identity everywhere: header, menus, email greetings. | The business name, falling back to first name and then email only until a business name is saved. | IA-3 |
| PROF-12 | P1 | The phone number is used only for contacting the owner about the account. | It isn't used for marketing, and the Privacy Policy says so. | 23.4 |

### Suite ONB — Onboarding and first run (23.5, ON-1–ON-4)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| ONB-01 | P0 | A brand-new user: sign up → verify → About your business → Choose a plan → Checkout → Add your first shop → Upload → Add costs → First results, on | Completed. Each step has its own route. The progress indicator shows steps 4–7 and can be | ON-1 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | a phone, an iPad and a desktop, with no help. | dismissed. | |
| ONB-02 | P0 | Refresh at every step, and sign out and back in mid-way. | It resumes at the first step you haven't finished. | ON-2 |
| ONB-03 | P0 | Abandon Checkout and cancel Checkout. | No charge. You return to Choose a plan with "No card was charged." The header shows the signed-in, no-plan state. | ON-3 |
| ONB-04 | P1 | An invited member. | Skips the plan and shop steps. | ON-4 |
| ONB-05 | P1 | The sample shop is reachable from the Control room header and from the Sample shop page at every stage. | Yes. Labelled Sample data and never counted. | 23.5 |

### Suite BILL — Plan & billing

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| BILL-01 | P0 | During a trial (each tier). | Shows: "Your trial ends on [date]. You won't be charged if you cancel before then.", the chosen plan, the first charge amount (founding price if eligible) and date, with the time zone named, and a clearly labelled **Cancel trial**. No Keep Pro. | 12.5A, V17 |
| BILL-02 | P0 | Paid. | Plan, interval, usage, the next payment date and amount (showing when the founding price ends and the price from month 7), invoices, change plan, update card, and a clearly labelled **Cancel subscription** you don't have to hunt for. | 5, V20 |
| BILL-03 | P0 | As a member. | Billing actions aren't available (SEAT-08). | 12.5A |
| BILL-04 | P1 | Past due. | A persistent banner with an update-card button and the deletion warning. | S7 |
| BILL-05 | P1 | Cancelled, with access still running. | "Cancellation scheduled — access ends [date/time]", the deletion date and Download my data. Undo is offered if Stripe still shows the subscription as active. | 12.5A |

### Suite CAN — Cancellation, including the optional reason (V19, 12.5A, K50, K51)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| CAN-01 | P0 | Owner, trial: Plan & billing → Cancel trial. | **One** confirmation step: "You will not be charged. You keep access until [exact date and time]. Your account will be closed and your data will be permanently deleted on [the same date and time]. Download your data before then. This cannot be undone." Download my data is prominent. Two actions: **Confirm cancel** and **Go back** (Go back is the default). | 12.5A, S28, S29 |
| CAN-02 | P0 | Owner, paid: Cancel subscription. | The paid wording ("Your subscription will not renew…") with the paid-period end date. | 12.5A |
| CAN-03 | P0 | **The reason is optional:** confirm **without** choosing or typing a reason. | Cancels straight away. No error, no extra step and no delay. | V19 |
| CAN-04 | P0 | The reason is on the same step. Check that choosing a reason doesn't add a screen, an offer or a delay, and that Confirm cancel is never hidden, disabled or moved off screen because of it. | One screen: the 12.5A wording, an optional "Why are you cancelling?" picker (Too expensive; Not using it enough; Missing a feature I need; Hard to use; My data or files didn't work; Switching to another tool; Business closed or paused; Other), an optional free-text box (up to 500 characters), then Confirm cancel and Go back. | 23.10, CA-1 |
| CAN-05 | P0 | Choose a reason and type 501+ characters including HTML, then confirm. Also make storing the reason fail (in staging). | The reason and text are stored when given (CA-2), with the text escaped and limited to 500 characters without blocking. If the reason fails to save, the cancellation **still** completes. | CA-2, V19 |
| CAN-06 | P0 | The reason after access end. | It stays linked to the account until access end, then is kept with **no** account or personal link (for reporting only). Check the database: no email, name or account ID left. | 23.13 |
| CAN-07 | P0 | **On the server:** after Confirm cancel, check Stripe. | The subscription is set to cancel at the period or trial end (`cancel_at_period_end`), or cancelled, per 12.5. The entitlement records the closure date and the deletion due. **Not just a message on screen** (G8). | 12.10, G8 |
| CAN- | P0 | After confirming. | An in-app confirmation, plus an email (EML-11) | 12.5A |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| 08 | | | repeating the access-end date, that the account will be closed, the deletion date, no charge or no renewal, and the export link. | |
| CAN-09 | P0 | Access after cancelling. | Full access and export until the stated end. Uploads are allowed while access remains (per 12.4). No early wipe. | D1, D2 |
| CAN-10 | P1 | Undo with "Keep my plan" before access end. | Resumes the same trial or period only if Stripe still shows it as active. No new trial. Members are told. | 23.10, 12.5A |
| CAN-11 | P0 | Look everywhere for any other way to cancel: Help centre, FAQ, the contact form, emails, Refunds and Terms. | Cancellation is only in Plan & billing. No email, phone or ticket route. The contact form's confirmation and the copy emailed to the user don't offer cancellation. | K50, S35 |
| CAN-12 | P0 | No retention maze: count the steps and look for offers. | One confirmation step and no retention offer (none was approved at launch). Cancel is as easy as keeping the plan. | 12.5A |
| CAN-13 | P1 | Cancel on a phone and an iPad, with VoiceOver. | Can be completed. Dates are read out. Go back is reachable. | 15.2.6 |

### Suite DEL — Account closure and data deletion

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| DEL-01 | P0 | Advance the clock past the access end of a cancelled trial and of a cancelled paid plan. Run the jobs. | Every category in 12.6 is gone from the live app, exports, search indexes, caches and derived stores: orders, costs, ads, overheads, settings, datasets, results, PDFs, scenarios, samples, **shops, team and member links, profile, contact and suggestion links to the account** (per Privacy). The login no longer works. | D3, D10, 12.6 |
| DEL-02 | P0 | Sign up again with the same email after closure. | A new, empty account. Nothing restored. No second trial (one per account or card, per the v20 rule). Founding eligibility per the v20 rule. | D6, S12 |
| DEL-03 | P0 | Backups: check the backup | Retention ≤ 7 days. A restore test re-applies the deletion records before access, so deleted data | D7, D8, |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | retention setting and a restore. | never comes back. | 19 |
| DEL-04 | P0 | Missed job: stop the scheduler for a day, then restart it. | It catches up once, alerts support, doesn't extend access and doesn't send duplicate notices. Access rules cut off at the stated time even if the job is late. | D9, 19.3 |
| DEL-05 | P0 | **Is data stored on the server or in the browser?** Inspect localStorage, IndexedDB and Cache Storage after an upload. Then sign in on a second device. | Product data is stored on the **server** and appears on the second device. Nothing about the product is left in browser storage after sign-out or deletion (G7). | G7, 10.2 |
| DEL-06 | P1 | A legacy lifetime account. | Its data is not wiped. Start fresh still works. | D11 |
| DEL-07 | P1 | What remains after access end. | Only Stripe's records, the legally required invoice, payment and tax records, and a deletion record that identifies no one. They match what the Privacy Policy says. | 12.6 |

### Suite HELP — Help centre and contact form (V7, V8)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| HELP-01 | P0 | Open the Help centre signed out, signed in, and as a closed or locked-out user. | It is a public page with its own URL. Reachable from the footer (and from the account menu, per the v20 design). | V7, F8 |
| HELP-02 | P1 | The **Hard limits & billing FAQ** has moved here from Pricing. | Every 3.2 question is present and **updated for v20**: the trial is the tier you choose (no "Starter, Growth and Pro trials include full Pro features", no "Keep Pro", no "during a trial the active limit is Pro's 5,000"); the founding offer is described; the copy says "Margins365"; and any "look at the sample report" wording now says Sample shop. Pricing no longer has the FAQ. | V7, V17, V20, S56, S64 |
| HELP-03 | P1 | FAQ items open with a tap, the keyboard (Enter or Space) and a screen reader (`aria-expanded`). | They work, and a refresh keeps the opened answer if the v20 design supports anchors. | 15.3, V5 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | Deep-link to one answer. | | |
| HELP-04 | P0 | Contact form fields and the notice. | Name (required), Phone number (optional), Business name (optional), Email (required), Country (required, from a list), Message (required, 10–5,000 characters). Signed in, the name, business name, email and country are pre-filled and can be edited. No attachments. The notice reads: "We use these details to answer your message. Don't include passwords or card details. See our Privacy Policy." (with a link). | 23.11 |
| HELP-05 | P0 | Validation: leave each required field empty; a 9-character and a 5,001-character message; an invalid email or phone; only spaces; emoji; right-to-left text; HTML or script. Also send a crafted request that skips the page. | An accessible error next to each field, with what you typed kept. The server applies the same rules. HTML is stored and shown as text. | HC-2 |
| HELP-06 | P0 | Submit a valid message. | **After** the message has been stored, a pop-up appears: "Thanks, [Name]. Your message has been sent. We've emailed a confirmation to [email]." It is shown in the page, **not the browser's alert box**. It has a Close button and keeps focus inside it. Closing returns focus to the form, which is then cleared. No reply time is promised. | 23.11, HC-5 |
| HELP-07 | P0 | Check the **info.marginos@gmail.com** inbox (or a staging stand-in set up the same way). | One email per submission, sent through SES from margins365.com, with the subject "Margins365 contact: [Name] — [Business name]", every field, the time and reply-to set to the visitor. It passes SPF, DKIM and DMARC and isn't in spam. | HC-3 |
| HELP-08 | P0 | Check the visitor's inbox. | One confirmation: "We've received your message", **without their message text** (K84, HELP-21), and no promise of a reply time. If the message mentions cancelling, one line: "To | HC-4, 23.11 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | cancel, the account owner uses Plan & billing." Margins365 branding, a plain-text version, passes SPF, DKIM and DMARC. | |
| HELP-09 | P0 | Abuse: 6 submissions from one IP in an hour; 4 to one email in an hour; filling the honeypot; submitting faster than the minimum fill time; scripting 100 submissions. | Limited to 5 per IP and 3 per email per hour, with a clear wait message. Bot submissions are silently refused. There is no third-party captcha. Someone else's inbox can't be flooded beyond 3 copies an hour (see section 10, gap 4). | 23.11, HC-2 |
| HELP-10 | P0 | Failures: (a) network or storage fails; (b) storage succeeds but SES sending fails. | (a) No pop-up, an error, and what you typed is kept. (b) The success pop-up **is** shown (the message is stored), an admin alert is raised, and the email is retried until sent. Check that both emails eventually arrive. | 23.11 |
| HELP-11 | P0 | Double-click submit, and retry after a timeout. | Only one record and one pair of emails. | HC-6 |
| HELP-12 | P0 | Admin inbox. | Viewable only by the authenticated admin (the owner of the business that runs Margins365). Ordinary and signed-out requests are refused. Messages are deleted 12 months after receipt (test with the clock). | 23.11, 23.13 |
| HELP-13 | P1 | Logs. | The message body, phone number and email address don't appear in application or error logs. | Nov 7, 19.3 |
| HELP-14 | P1 | Phone and iPad: fill in and send. | The right keyboards appear (email, tel). Targets ≥ 44 px. The pop-up fits the screen. The country picker can be used. | K48 |
| HELP-15 | P1 | The Privacy Policy covers contact submissions: what is collected, why, the legal basis, how long it's kept, that Google (Gmail) is a recipient, and international transfers if any. | Covered, and accurate. | V22, UK GDPR Art 13 |
| HELP- | P2 | Other Help centre content (how | Accurate for the v20 product, with no "[TO | V7 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| 16 | | to start, sign-in, files needed, shops and seats, downloads, cancelling and data, refunds, legal PDFs, suggest a feature). | COMPLETE]" left, and every link working. | |
| HELP-17 | P0 | **Suggest a feature**, signed in: send a suggestion. Check info.marginos@gmail.com and the admin list. | One email, from margins365.com through SES. Subject "Margins365 feature suggestion: [Business name] ([Plan])". It contains the text, name, account email, business name, plan and status, role, number of shops, account ID, time (Europe/London) and screen, with **Reply-To set to the submitter**. The suggestion is also stored. A success message shows in the page. No copy goes to the user. (Live today: stored only, no email, G17.) | K83, FS-1, FS-2 |
| HELP-18 | P1 | Suggest a feature: 6 in an hour; a double tap; 1,001 characters; signed out (the form, plus a direct request to the server); staging SES failure; storage failure. | Limited at 5 per hour and 20 per day. A double tap sends once. 1,001 characters are refused. Signed out, the form isn't offered and the server refuses the request (401). SES failure: success is shown, an alert is raised and the email is delivered after the retry. Storage failure: an error is shown and the text is kept. | K83, FS-3–FS-5 |
| HELP-19 | P2 | FAQ answer about recommending a feature (Pricing FAQ copy and Help centre). | It reads "Signed in, open Suggest a feature, write a short note and send it. It goes straight to the Margins365 team. We can't promise a reply." | K83 |
| HELP-20 | P0 | **Contact us**, signed out and then signed in: send one message each. Check info.marginos@gmail.com and the browser's network request. | Exactly one notification per send, from margins365.com, with Reply-To set to the visitor. Signed in, it also shows the account email, business name, plan and status, role and account ID (all from the session), plus a flag when the form email differs. Signed out, it's marked "Signed-out visitor". The browser request contains no recipient address. | K84, HC-7, HC-8 |
| HELP-21 | P0 | Check the visitor's confirmation email. | Subject "We've received your message — Margins365". It contains **no message text, phone number or other fields**, and Reply-To is info.marginos@gmail.com. The cancel line | K84, HC-9 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | appears only when the message mentions cancelling. | |
| HELP-22 | P0 | Spam checks: fill the hidden honeypot; submit within 3 seconds of opening the page; send a forged X-Forwarded-For to dodge the IP limit; restart the server between submissions. | Honeypot and too-fast submissions are refused silently (no email). The IP limit uses the real client IP, so forged headers don't bypass it. Limits survive a restart and apply across servers. | K84, HC-11 |
| HELP-23 | P1 | Message of 9, 10, 5,000 and 5,001 characters, in the page and directly to the server. | 10 to 5,000 are accepted and 9 and 5,001 are refused, with the same rules in both places (live today: 4,000). | K84 |
| HELP-24 | P1 | Failure paths: storage fails; storage works but the notification fails; the visitor confirmation fails. | Storage failure: no pop-up, an error, and the text kept. Notification failure: the success pop-up, an admin alert, and both emails arrive after the retry. A failed visitor confirmation doesn't block success. | K84, HC-12 |

### Suite LEG — Legal documents and compliance on the site (V22)

Judge everything against UK and EU rules: UK GDPR and the EU GDPR; PECR and the ePrivacy rules on cookies; the Consumer Contracts Regulations 2013; the Electronic Commerce Regulations 2002; the Companies Act trading-disclosure rules; the DMCC Act 2024; and the EU Consumer Rights Directive. Legal confirms how each applies. QA checks that what is published is **present, reachable, consistent and true to the product**.

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| LEG-01 | P0 | Find each document on the site: **Terms**, **Privacy Policy**, **Refunds & cancellation**, **DPA & subprocessors** and the **Cookie notice**. | Each is published and reachable from the footer on every page, signed out. | V22 |
| LEG-02 | P0 | Before you sign up: on the sign-up form and the Google button. | Links to the Terms and the Privacy Policy are shown **before** the account is created. A consent checkbox (if the v20 design uses one) is **not pre-ticked**, links to the current | V22 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | versions, and is required. The version accepted and the time are recorded on the server. | |
| LEG-03 | P0 | At checkout, before the card is entered. | Links to the Terms and Refunds & cancellation (and the founding-offer terms) are visible. Pre-contract information is complete: who the trader is, the total price including VAT, the trial length, when and how much the automatic charge is, the founding price and how long it lasts, how to cancel, and the refund policy. | V22, 12.5, CCR 2013 |
| LEG-04 | P0 | Signed out, open each document (HTML and PDF). | Readable with **no sign-in or payment** needed. A customer-specific signed DPA may need sign-in. The generic DPA template and the subprocessor list must be public. No "Sign in to view documents" in front of required information. | V22, F4, F10 |
| LEG-05 | P1 | Open each legal document from the footer, sign-up, Checkout and the Help centre. | Each opens in a **new tab** (`target="_blank" rel="noopener noreferrer"`). The PDF and HTML are A4-readable, use "Margins365" in the file name, and work on iPhone and iPad (no blank tab, no download loop). The right content type is set. | K74, LG |
| LEG-06 | P0 | Every document shows a **version number and effective date**, and the HTML and PDF versions match. | Yes. There is a "last updated" date. Earlier versions are kept (or there is a change log) if the v20 | V22 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | design says so. | |
| LEG-07 | P0 | **No placeholders left:** search each document for "[TO COMPLETE]", "DRAFT", "TBC", "XXX" or "lorem". | **None.** Any found is P0. | V22 |
| LEG-08 | Pre-launch | **Business identity details:** the documents use the trading name **Margins365**, with a working contact (the Help centre form and info.marginos@gmail.com). Registered address, company number, company type, country of registration and ICO registration number are not published yet. | Registered address, company number and ICO number to be added before launch if required (UK Companies Act trading disclosures). This is a **pre-launch check, not a P0 release blocker**. Record whether the details are present; do not fail the build on their absence. | E-Commerce Regs 2002 reg 6; Company Names & Trading Disclosures Regs 2015 |
| LEG-09 | P0 | **The documents match the product.** Check each fact against how the product actually behaves: trial = the tier you choose, 14 days, card upfront; charged on day 15; reminder 3 days before; cancel only by the owner, in-platform, in one step with an optional reason; access until the end of the period; account closed and **all data wiped** at the end of access, with backups gone within 7 days; first-payment refund within 14 days, once; founding offer 50% for 6 months for the first 100 paying users; hard order limits; shops and seats per tier; no email cancellation. | Every fact matches the live behaviour **and** the other documents. Any mismatch is P0. | V22, 12.5–12.6 |
| LEG-10 | P0 | **The processor list matches reality:** DigitalOcean (London LON1: app, database, backups); Amazon SES / AWS (Stockholm, eu-north-1: email); Stripe / Link (payments); Google (sign-in, and **Gmail** as the contact-form inbox); Cloudflare (the `__cf_bm` cookie | All listed with their role, location and transfer safeguards, including Cloudflare (the `__cf_bm` cookie) and Gmail. Anything in use but not listed is P0. | V22, UK GDPR Art 28 and 13(1)(e)–(f) |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | shows it is in use as a proxy or CDN); and any logging or monitoring tool.<br><br>Privacy Policy contents: who the controller is and how to contact them; a privacy contact that works without signing in; the purposes and legal bases; the recipients; international transfers; how long data is kept (account, billing, contact form, cancellation reasons, logs); people's rights; the right to complain to the ICO (and an EU supervisory authority, if relevant); whether giving data is required; and any automated decision-making (none). | | |
| LEG-11 | P0 | | All present and accurate. | UK GDPR Art 13 |
| LEG-12 | P1 | DPA: Article 28 terms (instructions, confidentiality, security, subprocessors with authorisation and notice of changes, help with data-subject rights, breach notice, deletion or return, audit). | Present. A change-notice method is defined. A public template is available. | Art 28 |
| LEG-13 | P0 | Refunds & cancellation: owner-only cancellation in Plan & billing; access until the end; the closure and deletion dates; the first-payment refund rule and **how to request it**; statutory rights unaffected; no email cancellation; and what happens to the founding price. | All present, consistent with the Terms and the product. | V22, K50 |
| LEG-14 | P0 | Terms: the service description, plans and prices including VAT, the trial and automatic renewal, order limits, shops and seats, the founding-offer terms, how to cancel, refunds, data and deletion, liability, changes to terms and prices (with notice), and the governing law and courts. | Present, with no placeholders and consistent with the product. | V22 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| LEG-20 | P1 | Contract confirmation on a durable medium: after checkout, does the user receive the key terms (or a link to the version accepted) by email? | Yes: the trial confirmation includes them or links to the accepted version. | CCR 2013 reg 16 |
| LEG-21 | P1 | EU consumer withdrawal function (if EU consumers can subscribe). | Legal confirms whether it applies. If it does, there is an easy online withdrawal or cancel function. Plan & billing cancellation may meet this; record the result. | EU Directive 2023/2673 (legal to confirm) |
| LEG-30 | P0 | **Cookie and storage inventory:** with an empty browser, visit each public page, then sign in. List every cookie, localStorage, sessionStorage and IndexedDB item (name, provider, purpose, how long it lasts). | Every item is listed in the Cookie notice with its purpose. Currently at least the Cloudflare `__cf_bm` cookie, the session cookie, and localStorage keys (`marginos.*`, banner dismissal, tokens, audit). | V22, PECR reg 6, G12 |
| LEG-31 | P0 | Non-essential storage (analytics, ads, preferences that aren't strictly needed). | None set **before** consent. With K79 the only optional item is Plausible analytics (no cookies), loaded only after Accept; the banner has equally easy Accept and Reject, no pre-ticked boxes, and consent can be withdrawn later (suites CONS and ANL). | PECR, ePrivacy, K79 |
| LEG-32 | P1 | Third-party requests: check the network on every page. | Only the services listed (Stripe on checkout, Google on sign-in, Cloudflare). No third-party font servers (fonts are self-hosted). The only analytics host is Plausible's, and only after Accept (ANL-01, ANL-08). | 22.11 |
| LEG- | P1 | The Cookie notice is linked from the | Yes. | V22 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| 33 | | footer (or the Privacy Policy) and has a version and date. | | |
| LEG-40 | P0 | Honest pricing everywhere (DMCC Act 2024): the full price is shown up front; nothing extra added at checkout; the founding offer's countdown or "places left" is true; any "was / now" price is genuine. | Pass, with no misleading urgency. | V20, DMCC Act 2024 |
| LEG-41 | P1 | Accessibility statement (if the v20 design includes one). | Published and accurate. | WCAG |

### Suite EML — Every email the system sends

For each email: send it to Gmail, Outlook and iCloud. Check how it looks in light and dark mode, on a phone and on desktop. Inspect the raw headers.

| ID | P | Email | Expected result | Ref |
|---|---|---|---|---|
| EML-01 | P0 | Email verification | The link expires after 24 hours and is single-use, on margins365.com. Subject and From name use Margins365. | 22.8, AUTH-03 |
| EML-02 | P0 | Password reset | AUTH-14. The link expires after 60 minutes. | 5.1 |
| EML-03 | P1 | Google-only sign-in reminder | AUTH-17. | Q34 |
| EML-04 | P0 | "Your password was changed" | AUTH-18. | 5.1 |
| EML-05 | P0 | Trial confirmation | Chosen plan, amount (founding price and when it ends, if eligible), charge date with time zone, cancel in Plan & billing, links to the accepted terms. No Pro trial wording. | 12.5, V17, V20, LEG-20 |
| EML-06 | P0 | Trial reminder (3 days before) | CHK-08. | 12.5A |
| EML- | P1 | Receipt and invoice | Margins365 name, correct amount including VAT, | 3, 5 |

| ID | P | Email | Expected result | Ref |
|---|---|---|---|---|
| 07 | | (Stripe or Link) | explains the statement descriptor. | |
| EML-08 | P1 | Annual renewal reminder | Sent before an annual renewal (timing per the v20 design or legal), with the amount, date and how to cancel in Plan & billing. | 16.5 |
| EML-09 | P0 | 80% of the order limit | Goes to the **owner and the members**, once per billing month, naming the next plan and its limit and the current usage. | L11, 23.12 |
| EML-10 | P0 | Failed payment, retries, update card | Warns that final failure ends access and wipes the data, with an export link. | S7 |
| EML-11 | P0 | Cancellation confirmation | CAN-08. | 12.5A |
| EML-12 | P0 | Deletion completed | Sent when the wipe runs. States what was deleted. Contains no data. | 12.6 |
| EML-13 | P1 | Final failure / refund deletion notices | Per 12.6. | 12.6 |
| EML-14 | P0 | "Founding price ends soon" | OFF-13. | 12.5C |
| EML-15 | P0 | Contact form: the notification and the visitor's copy | HELP-07, HELP-08. | 23.11 |
| EML-16 | P0 | Invitation | Subject "[Business name] invited you to Margins365". An Accept button to `/invite/:token`, valid for 7 days and single use. Sent from margins365.com through SES. | 23.3, ST-2 |
| EML-17 | P1 | "You no longer have access to [Business name] on Margins365", and the members' copy of the dated cancellation warning | Correct and timely. Contains no data. | 23.3, 23.12 |
| EML-18 | P0 | **Every email:** | SPF pass, DKIM pass (signed by d=margins365.com), DMARC pass and aligned. The DMARC policy is moving | 20.5.4, |

| ID | P | Email | Expected result | Ref |
|---|---|---|---|---|
| | | **authentication** | from `p=none` to quarantine or reject once monitoring is clean. Return-Path on `mail.margins365.com`. Sent from SES eu-north-1. | V21 |
| EML-19 | P0 | **Every email: content** | Every link and image is hosted on margins365.com (**no marginos.online**, including in tracking or unsubscribe links). There is a plain-text version. No marketing in transactional mail. The footer says why you got it and gives the support contact. No invitation to reply or email to cancel. Logo alt text "Margins365". Readable in dark mode. 600 px single column. | 22.8, V1, V21 |
| EML-20 | P1 | Every email: delivery | Lands in the inbox, not spam, at Gmail, Outlook and iCloud. A mail-tester score of 9/10 or higher. | 16.5 |
| EML-21 | P1 | Bounces and complaints | SES bounce and complaint handling is set up. A bounced address is flagged. A failed reminder raises a support alert (12.5). | 12.5A |
| EML-22 | P0 | **SES evidence:** screenshots of the SES console (eu-north-1). | The margins365.com identity shows **Verified**, DKIM **Successful**, and MAIL FROM `mail.margins365.com` **Successful**. The account dashboard shows **production access** (not sandbox). | K86, ES-1, ES-2 |
| EML-23 | P0 | Send a reset and a contact confirmation to a **fresh, unverified** Outlook address and a fresh iCloud address. | Both arrive in the inbox, which proves production access. Raw headers show SPF pass, DKIM pass `d=margins365.com` and DMARC pass. | K86, ES-3 |
| EML-24 | P1 | DNS lookup: apex TXT, `_dmarc`, `mail.` MX and TXT, and the 3 DKIM CNAMEs. | Apex SPF `v=spf1 include:amazonses.com ~all` is published. DMARC has a reporting address, with the move to quarantine dated. The MAIL FROM records are present. The DKIM CNAMEs resolve. | K86, ES-5 |
| EML-25 | P1 | Every email's headers, and the SES mailbox simulator (bounce and complaint addresses). | Reply-To is set as K86 says (notifications to Akthar → the sender; customer emails → info.marginos@gmail.com). No email asks for a reply to a margins365.com address. Simulated bounces and complaints are flagged and not mailed again. | K86, ES-4 |

### Suite DOM — Moving off marginos.online (V21)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| DOM-01 | P0 | Search the built bundle, the HTML, emails, PDFs, legal documents, meta tags, the sitemap and the Stripe and Google settings for `marginos.online` and `marginos.com`. | No customer-facing matches. (The contact inbox info.marginos@gmail.com is approved in K65 and appears in the Terms. That is allowed, but log it for Akthar, see section 10.) Code identifiers such as storage keys may stay (K59). | K73 |
| DOM-02 | P0 | Google OAuth client. | margins365.com origins and redirect URIs work. marginos.online entries are removed once the switch is proven. The consent screen links point to margins365.com. | V21, 20.5.3 |
| DOM-03 | P0 | SES. | The margins365.com identity is verified, with DKIM, SPF and MAIL FROM. No sending from a marginos.online identity. | V21, 20.5.4 |
| DOM-04 | P0 | Stripe: success, cancel and portal return URLs, the webhook endpoint, business website, support URL and the terms and privacy links. | All on margins365.com. | V21, 20.5.5 |
| DOM-05 | P1 | The old domain while it still exists: `http://` and `https://marginos.online/any/path?x=1`. | A 301 redirect to the same path on `https://margins365.com` (today it redirects to the home page only). HSTS on the new domain. | V21 |
| DOM-06 | P0 | **Retiring the old domain.** Under K73, the marginos.online redirect stops when the domain is cancelled. | Confirm (with Development) that nothing still depends on it: no old reset or verify links still valid, no customer-facing URLs, no OAuth or SES dependency. Record the cancellation date. Recommend Akthar keeps the domain registered but parked to prevent impersonation (see section 10). | K73 |
| DOM-07 | P1 | `www.margins365.com` | Redirects (301) to `https://margins365.com`, or is set as canonical. | V21 |

### Suite MOB — Phones and pop-ups (K80, K81; spec 23.19.1–23.19.2)

Run on a real iPhone (Safari, with the address bar both shown and hidden; scroll a little to hide it), an Android phone (Chrome), Samsung Internet and an iPad (portrait and landscape). Also run on the smallest supported phone size, 320 × 568 (iPhone SE class). Record a screen video for every Fail.

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| MOB-01 | P0 | Open the **plans / free-trial pop-up** from every entry point (header, Start here, Pricing cards, Sample shop), signed out and signed in with no plan. Try to reach the top and the bottom. | **Close** stays visible. The content scrolls **inside** the pop-up. **Start 14-day free trial** and **Not now** can be reached and tapped without zooming, and never sit behind the Safari toolbar or home indicator. The page behind doesn't move. (Live today: the pop-up is 1,541 px tall on a 664 px screen and can't be scrolled, G14.) | K80, MOB-1, MOB-2 |
| MOB-02 | P0 | Sign in, Sign up, verify email, profile completion, Forgot password and Set new password pop-ups, with the on-screen keyboard open on each field. | The focused field and the submit button stay visible or reachable while the keyboard is open. Close stays visible. Nothing is cut off. | K80, MOB-4 |
| MOB-03 | P0 | **Cancel trial / Cancel subscription** confirmation with the 8 optional reasons and the note, at 320 × 568 and 390 × 664. | **Confirm Cancel** and **Go Back** are reachable whether or not a reason is chosen. The reason never blocks cancelling. | K80, K71 |
| MOB-04 | P1 | **Clear sample data** and **Delete my shop data** confirmations. | Both buttons are reachable, and the text can be read in full. | K80 |
| MOB-05 | P1 | Contact success pop-up, account menu, shop switcher (Scale), invite and remove member, and the phone navigation menu, in portrait and landscape. | Every control is reachable. Each scrolls inside if it's longer than the screen. | K80 |
| MOB-06 | P0 | First visit (no consent stored): open any pop-up while the cookie banner is showing. | The pop-up sits **above** the cookie banner, and the banner never covers a pop-up control. The cookie banner's own buttons sit clear of the home indicator. | K80, MOB-3, D-2 |
| MOB-07 | P1 | Background lock: scroll halfway down a page, open a pop-up, then swipe inside it and on the dimmed area. Close it. | The page behind doesn't scroll, and swipes inside the pop-up don't pass through to it. After closing, the page is exactly where it was. | K80, MOB-2 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| MOB-08 | P1 | Keyboard and VoiceOver / TalkBack with each pop-up. | Focus moves into the pop-up and stays there. Escape and Close both close it. Focus returns to the button that opened it, and the pop-up title is announced. | K80, MOB-5, WCAG 2.4.3 |
| MOB-09 | P1 | With a pop-up open: rotate the device; set iOS text size to the largest; zoom the browser to 200%. | Every control is still reachable. No content is lost. | K80 |
| MOB-10 | P0 | **Site-wide mobile check:** every public page and every signed-in screen at 320, 375, 390, 414 and 430 px wide, on iPad portrait and landscape, on iPhone Safari (bar shown and hidden), Android Chrome and Samsung Internet. | No sideways page scrolling. Nothing hidden behind fixed bars. Every button is reachable and at least 44 × 44 px. Forms work with the keyboard open. Body text needs no pinch-zoom. Log a pass or fail per page and device. | K80, MOB-6, 15.3 |
| MOB-11 | P1 | The sticky header in portrait on a 390 × 664 screen, on every public page. | It takes no more than about a sixth of the screen height (live today: header plus banner take 199 px) and never covers a page heading. | K80, K81 |
| MOB-12 | P1 | **Banner removed:** on every page, signed in and out, on every device, and in a text search of the built site and the prerendered HTML. | No "14 days free. Cancel before day 14 and pay nothing. From £39/mo" banner and no dismiss control. The header is the top element, with no empty strip. | K81, BN-1, BN-2 |
| MOB-13 | P0 | After the banner removal, check the trial terms. | The terms required before purchase are still shown on the Pricing cards, in the plans pop-up and at Checkout (LEG-03, CHK-02). | K81, BN-3 |

### Suite RESP — Phone, iPad and desktop layout (K45, K48)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| RESP-01 | P0 | **Screenshot matrix:** capture every public page (Home, Sample shop, Pricing, Help centre including the form and pop-up, Sign in, reset, Terms, Privacy, Refunds, DPA, Cookie notice, 404) and the core signed-in screens (Control room, upload, import review, Info, Plan & billing, cancel confirmation, shop switcher, | Each screenshot is marked pass or fail against: type sizes, 44 px targets, content width, no empty region on one side, hero scaling, and no zoomed-out page. **Any fail** | 15.5, S33 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | team and seats) at 390×844, 768×1024, 834×1194, 1024×768, 1194×834, 1280×800, 1440×900 and 1920×1080, plus 320×640. | **blocks release.** | |
| RESP-02 | P0 | Type sizes, measured with devtools: body text ≥ 16 px; section headings ≥ 24 px (phone) and ≥ 28 px (larger); page headlines ≥ 28, 32, 36 and 40 px at the four widths. | They pass at every breakpoint. | 15.5 |
| RESP-03 | P0 | Pricing comparison on a phone and on iPad portrait and landscape. | Stacked rows, or a table that scrolls sideways **inside the table only**, with the Capability column fixed and a visible hint that there's more. iPad landscape is readable without scrolling sideways or pinch-zooming. | 15.3 (regression surface) |
| RESP-04 | P0 | Home hero on iPad (the 6 Nov regression surface). | It follows K48: the image scales with the text, no floating card, no empty band wider than 12% on one side. | 15.5, S59 |
| RESP-05 | P1 | The sticky header on short tablet screens. | It never covers headings or tables. No sticky banner (K81). | 15.3, K81 |
| RESP-06 | P1 | Sample card and ranked leaks on a phone and an iPad. | No clipping of £ amounts or leak names, and no pinch-zoom needed. | S57 |
| RESP-07 | P1 | The business-name button, the shop switcher and the account menu at 320 px. | Usable, with nothing overlapping. The header doesn't wrap onto two lines. | V11, V12 |
| RESP-08 | P1 | Rotate the device mid-task (upload, cancel, contact form). | No data lost, and the layout adjusts. | 15.3 |
| RESP-09 | P1 | 200% and 400% browser zoom (reflow at 320 CSS px). | Content reflows with no sideways scroll for core tasks and no content lost. | WCAG 1.4.10, 15.1 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| RESP-10 | P2 | Large desktop (2560 px). | Centred, with the content up to 1,440 px wide and equal margins. | 15.5 |

### Suite XB — Browsers

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| XB-01 | P0 | The core journeys (sign up → trial → upload → results → invite → switch shop → cancel; contact form; legal PDFs) on Chrome, Safari, Edge and Firefox (latest 2 versions each), Samsung Internet, iOS Safari and Android Chrome. | All pass. | 15.1 |
| XB-02 | P1 | Safari private mode and blocked third-party cookies. | Sign-in, checkout return and Google sign-in still work. | 15.1 |
| XB-03 | P1 | JavaScript disabled. | Public legal pages are still readable (server-rendered HTML or static pages), and other pages say clearly that JavaScript is needed. | V22, 15.1 |
| XB-04 | P2 | A slow 3G connection and offline mode. | Clear loading and offline states. No double submissions. | 15.2.10 |

### Suite A11Y — Accessibility (WCAG 2.2 AA)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| A11Y-01 | P0 | Run axe on every page in the RESP-01 list. | Zero serious or critical issues. | 15.1 |
| A11Y-02 | P0 | Keyboard only: every core journey, including the account menu, shop switcher, invite dialog, cancel confirmation, the contact-form pop-up, FAQ panels and tooltips. | Everything can be reached and used. The order is logical. Focus is always visible (a 3 px teal ring). No keyboard traps. Escape closes dialogs. Focus returns to where it was. | 2.1.1, 2.4.3, 2.4.7, 2.4.11 |
| A11Y-03 | P0 | Screen readers (VoiceOver on iOS and macOS, NVDA, | Names, roles and states are announced. Errors are announced. Route changes are announced | 4.1.2, 4.1.3, |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | TalkBack): the same journeys. | (NAV-26). The shop-icon button is announced as "Open Sample Shop". The Health Score is announced with its band and confidence. | 1.1.1 |
| A11Y-04 | P0 | Colour contrast: text ≥ 4.5:1, large text and interface parts ≥ 3:1. Colour is never the only signal. | Pass. The section 22 tokens hold. | 1.4.3, 1.4.11, 1.4.1 |
| A11Y-05 | P1 | Target size ≥ 24 px (WCAG 2.2), with the product standard of 44 px. | Pass. | 2.5.8, 15.1 |
| A11Y-06 | P1 | Form labels, instructions, autocomplete, error suggestions, and not asking for information already given (prefill). | Pass: contact form, Info, sign-up, reset, cancellation reason. | 1.3.5, 3.3.1–3.3.3, 3.3.7 |
| A11Y-07 | P1 | Accessible sign-in: no puzzle that relies on memory or thinking. Paste is allowed in password fields. Password managers work. | Pass. | 3.3.8 |
| A11Y-08 | P1 | Charts have text alternatives. Tables have headers. Headings are in a logical order. Each page has a unique title. A skip link exists. | Pass. | 1.1.1, 1.3.1, 2.4.1, 2.4.2 |
| A11Y-09 | P2 | Reduced motion and animation. | `prefers-reduced-motion` is respected. | 2.3.3 |
| A11Y-10 | P1 | PDFs (legal documents and the report). | Tagged, with a reading order, a title and language set, where possible. | 1.3.1 |

### Suite SEC — Security, isolation and permissions

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| SEC- | P0 | **Tenant isolation:** signed in as Account A, request | 403 or 404 every time. No | 12.6, |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| 01 | | every API object of Account B by changing IDs (shops, datasets, results, PDFs, exports, invoices, members, invites, contact records, suggestions, cancellation records). | data and no metadata leaked. | V15, V16 |
| SEC-02 | P0 | **Role checks (IDOR):** as a member, call every owner-only endpoint (cancel, billing, portal session, invite, remove, shop add/remove, Start fresh, profile edit, export if restricted). | 403. | V16, 12.5A |
| SEC-03 | P0 | **Plan checks:** call Scale-only and Growth-only endpoints from a lower plan; send a modified plan, limit or seat count in requests. | Refused. Every entitlement is checked on the server. | 12.5 |
| SEC-04 | P0 | Protected files: report PDFs, exports, signed DPAs. Try a direct URL signed out, as another account, with a HEAD or range request, after sign-out, and via a cached copy. | Refused every time. No CDN or cache leak. No long-lived tokens in links. | F6, F7 |
| SEC-05 | P0 | Browser storage after sign-out (G7). | No product data, tokens or personal data left in localStorage, sessionStorage or IndexedDB. | G7, 10.2.2 |
| SEC-06 | P0 | CSRF: send state-changing requests from another origin. | Refused (SameSite cookies plus a CSRF token or origin check). | 12.6 |
| SEC-07 | P0 | Upload security: oversize files, a zip-bomb XLSX, wrong MIME types, path traversal in the file name. | Refused safely, with no server crash. | 6, Q10 |
| SEC-08 | P0 | Rate limits: sign-in, sign-up, reset, verify, contact form, invite, checkout creation, suggestions. | Each is limited, with neutral messages. Rate limits are stored so they survive restarts and work across server instances (not just in memory). | 16.5, V8 |
| SEC-09 | P0 | Secrets: search the bundle, HTML and network responses for API keys (Stripe secret, AWS, Google client secret, database URLs). | Only publishable keys. | 16.4 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| SEC-10 | P0 | Logs: trigger errors with personal data, tokens and passwords in the input. | Not logged. | 10.2.2, 19.3 |
| SEC-20 | P0 | HTTPS: HTTP → HTTPS redirect; TLS 1.2+ only; a valid certificate on the apex and www domains. | Pass. | — |
| SEC-21 | P1 | Security headers on HTML and API responses: Strict-Transport-Security (with includeSubDomains), Content-Security-Policy, X-Content-Type-Options: nosniff, a frame-ancestors / X-Frame-Options policy, Referrer-Policy and Permissions-Policy. | Present and sensible (currently missing, G10). | G10 |
| SEC-22 | P1 | Clickjacking: load the app in an iframe on another site. | Blocked. | G10 |
| SEC-23 | P1 | CORS on the API. | Only margins365.com is allowed. Credentials aren't allowed from other origins. | — |
| SEC-24 | P1 | Caching of signed-in responses. | `Cache-Control: no-store` (or private) on personal data. | AUTH-10 |
| SEC-30 | P0 | Cross-site scripting (XSS): enter `<img src=x onerror=alert(1)>` in every free-text field (business name, shop name, member name, contact message, cancellation reason, suggestion, product names inside CSVs). Then view it in the app, emails, the PDF and the admin views. | Shown as text everywhere and never runs. | SEC |
| SEC-31 | P1 | Email header injection through the contact form (line breaks in the name or email). | Cleaned out. No extra recipients. | V8 |
| SEC-32 | P1 | Admin pages (contact inbox, suggestions, the founding counter). | Need admin sign-in checked on the server (two-factor recommended). Not reachable by ordinary users. | Nov 7 AC4 |
| SEC-33 | P1 | Google OAuth: `state` and nonce checks; the ID token checked on the server (issuer, audience, expiry, signature). | Pass. The live bundle calls Google's userinfo endpoint from the browser, so confirm the server checks the ID | 16.5 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | token itself. | |

### Suite PRIV — Privacy and data rights

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| PRIV-01 | P0 | Download my data (CSV). | Contains the cleaned orders, costs and settings (and the profile, per the v20 design). Never the original file or buyer personal data. Available until access end. Opens correctly in Excel and Sheets (UTF-8, cells protected against formulas). | 10.2.5, 12.7 |
| PRIV-02 | P0 | Data locations: check the infrastructure settings. | App, database and backups in DigitalOcean LON1. Email through SES eu-north-1. Matches the Privacy Policy. | K36, 19.4.1 |
| PRIV-03 | P1 | Subject requests (access, correction, erasure) through the privacy contact while signed out or closed. | The route exists and is published. Not hidden behind sign-in. | LEG-11 |
| PRIV-04 | P1 | Collect only what's needed: list every field collected (sign-up, Info, contact form, cancellation, invites). | Each one is justified in the Privacy Policy. Nothing undisclosed is collected (for example, no device fingerprinting). | UK GDPR Art 5(1)(c) |
| PRIV-10 | P0 | Cookies and storage: LEG-30 and LEG-31. | Pass. | PECR |

### Suite PERF — Performance

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| PERF-01 | P1 | Lighthouse and WebPageTest on Home, Pricing, Sample shop and Help centre (mobile, simulated 4G, mid-range phone). | LCP ≤ 2.5 s, INP ≤ 200 ms, CLS ≤ 0.1. | 15.2.10 |
| PERF-02 | P1 | Results ready after the reference upload (1,000 orders) on a mid-range phone with 4G. | Usable within 3 seconds after processing. | 15.2.10 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| PERF-03 | P1 | Large import: 50,000 rows. | Finishes within the time set in the v20 design, with a progress indicator. No browser freeze. Processed on the server. | Q10 |
| PERF-04 | P2 | 20 people using the app at once and 5 uploading at once (load test on staging). | No errors. Order limits stay correct (L8). | L8 |
| PERF-05 | P2 | JavaScript bundle size. | Recorded. Flag anything over 500 KB compressed on the first load (the current bundle is about 870 KB uncompressed). | — |

### Suite SEO — Search engines, metadata and discoverability (K75, `/workspace/v20/Margins365-SEO-v20.md`)

Run on the production build at margins365.com (staging must be noindexed, see SEO-07). Use curl or "View source" for anything about the **HTML before JavaScript**, a headless crawler (for example Screaming Frog with JavaScript off, then on) for links, Google's Rich Results Test and the Schema.org validator for structured data, and Lighthouse for speed. The exact titles and descriptions are in SEO spec 5.1. Akthar or a developer with access verifies Search Console and Bing.

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| SEO-01 | P0 | `curl` each public route (`/`, `/sample-shop`, `/pricing`, `/help`, five `/legal/...` pages) with no JavaScript. | Each response contains that page's full visible text (H1, headings, body copy, prices, FAQ answers, legal text) and the header/footer links. It is not the empty `<div id="root">` shell, and no two routes return identical HTML. | SEO 3, A1 |
| SEO-02 | P0 | Compare the no-JavaScript HTML with the rendered page for each public route, using a normal browser user agent and then Googlebot's. | Same content for both user agents (no cloaking). The rendered page doesn't remove or replace the prerendered text. Hydration causes no visible jump. | SEO 3.3 |
| SEO-03 | P1 | Signed-in pages `/app`, `/app/shops`, `/account/info`, `/welcome`, `/invite/<token>`. | Each sends `X-Robots-Tag: noindex`, is disallowed in robots.txt, isn't in the sitemap and isn't linked from public pages except through Sign in. | SEO 3.5, 6 |
| SEO-04 | P0 | Each public page: read `<title>` and meta description from the raw HTML. | They match SEO spec 5.1 exactly. Every title is ≤ 60 characters, unique and contains "Margins365". Every description | SEO 5, V1, V2 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | is ≤ 155 characters and unique. No "Margins 365", "MarginOS" or "Sample report". | |
| SEO-05 | P1 | Each public page: count H1s; list the heading order. | Exactly one H1, matching spec 5.1. H2/H3 levels never skip (no H1 → H3). | SEO 5, 11 |
| SEO-06 | P0 | Each public page: read the canonical and robots meta. | `<link rel="canonical">` is the absolute `https://margins365.com/<route>` of the page itself (no www, no trailing slash, no query). Indexable pages have `index, follow`; `/sign-in` `noindex, follow`; `/reset-password` `noindex, nofollow`. | SEO 5.1 |
| SEO-07 | P0 | Production and staging: check the `X-Robots-Tag` header and robots meta on Home. | Production has **no** site-wide noindex. Staging has `noindex, nofollow` and a password. | SEO 6 |
| SEO-08 | P1 | Fetch `/robots.txt`. | Status 200, `text/plain`, content exactly as SEO spec 6, including the Sitemap line. Lighthouse "robots.txt is valid" passes. | SEO 6, A4 |
| SEO-09 | P1 | Fetch `/sitemap.xml` and validate it. | Status 200, XML content type, valid sitemap. It lists exactly the indexable public pages (absolute https://margins365.com URLs, no www) with real `lastmod` dates. No signed-in, sign-in, reset, PDF or marginos.online URLs. Every listed URL returns 200 and is canonical to itself. | SEO 13 |
| SEO-10 | P0 | Request `/this-does-not-exist`, `/pricing/extra`, `/legal/nothing`. | Status **404** (not 200), branded 404 page with the spec 5.1 title, `noindex`, links to Home, Pricing and Help centre. | SEO 4, ERR-01, A4 |
| SEO-11 | P1 | Request `https://www.margins365.com/pricing?x=1`, `/pricing/`, `/Pricing`, `/sample-report`. | Each 301-redirects in **one hop** to `https://margins365.com/pricing?x=1`, `/pricing`, `/pricing` and `/sample-shop`. | SEO 7, A7 |
| SEO-12 | P0 | From a normal internet connection, request `http://margins365.com/help` and | One 301 hop to `https://margins365.com/help`. The HTTPS response has `Strict-Transport-` | SEO 7, A14, SEC-2 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | `http://www.margins365.com/help`. | `Security` with max-age ≥ 31536000. | 0 |
| SEO-13 | P1 | Request `https://marginos.online/pricing?a=1`, `http://marginos.online/`, `https://www.marginos.online/help` (while the domain is still held). | 301 to the same path and query on `https://margins365.com`. www.marginos.online either redirects the same way or the gap is logged for Akthar. | SEO 7, K73, DOM |
| SEO-14 | P1 | Crawl the site with JavaScript **off**, starting at Home. | Every public page is found by following `<a href>` links alone. Header, footer, "Start here", Sample shop and Help links are `<a href>` elements, not buttons. No `href="#"` or `javascript:` links. | SEO 11, A3 |
| SEO-15 | P2 | List every internal link's text on public pages. | Descriptive text; no "click here" or "read more" alone. Internal links match the linking map in SEO spec 11. | SEO 11 |
| SEO-16 | P1 | Each public page: read the Open Graph and Twitter tags. | `og:title`, `og:description`, `og:url` (= canonical), `og:type` website, `og:site_name` "Margins365", `og:locale` en_GB, `og:image` (absolute https), `og:image:width` 1200, `og:image:height` 630, `og:image:alt`; `twitter:card` summary_large_image with title, description, image and alt. | SEO 8, PUB-16 |
| SEO-17 | P2 | Paste Home, Pricing and Sample shop links into LinkedIn Post Inspector, the Facebook Sharing Debugger, WhatsApp and Slack. | Correct title, description and image show. No founding-offer price appears in the image. | SEO 8 |
| SEO-18 | P2 | Fetch the OG image. | 1200 × 630, PNG or JPG, < 300 KB, status 200, long cache. Text inside the centre safe area. | SEO 8 |
| SEO-19 | P1 | Fetch `/favicon.ico`, `/icon.svg`, `/apple-touch-icon.png`, `/icon-192.png`, `/icon-512.png`, `/icon-maskable-512.png`, `/site.webmanifest`. | Each returns 200 with its real content type (not the Home HTML) and the sizes in SEO spec 9. The manifest has name and short_name "Margins365", start_url "/", theme_color #34726B and lists the icons. The `<head>` links to them. | SEO 9, A11 |
| SEO- | P1 | Run Home and Pricing through the Rich | Organization, WebSite and | SEO |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| 20 | | Results Test and the Schema.org validator. | SoftwareApplication (WebApplication) parse with no errors. Offers are in GBP with prices 39/79/129/199 monthly and 390/790/1290/1990 annual, VAT included, matching the page. No `aggregateRating` or `review` unless genuine reviews are shown on the page. | 10 |
| SEO-21 | P2 | Help centre (and Pricing if it still shows an FAQ): validate FAQPage. | FAQPage parses with no errors and every question and answer matches the visible FAQ word for word. (No FAQ rich result is expected in Google since May 2026.) | SEO 10 |
| SEO-22 | P2 | Every public page except Home: validate BreadcrumbList. | Valid; names and URLs match the page path (for example Home › Legal › Terms). | SEO 10 |
| SEO-23 | P1 | Read `<html lang>` and the hreflang tags on every public page. | `lang="en-GB"`. `hreflang="en-GB"` and `hreflang="x-default"` both point to the page's own canonical URL. | SEO 13 |
| SEO-24 | P1 | Lighthouse mobile (simulated throttling), 3 runs each, median, on Home, Pricing, Sample shop and Help centre. | LCP < 2.5 s, CLS < 0.1, TBT < 200 ms, Performance ≥ 90, SEO 100, Best Practices ≥ 95, Accessibility 100. No console errors when signed out. Record the scores. (Baseline 11 Nov: Home Performance 89, LCP 2.9 s, CLS 0.079.) | SEO 12, PERF-01, A8 |
| SEO-25 | P2 | Public pages: total JavaScript downloaded on first load (compressed). | ≤ 150 KB, and the signed-in app, charts and import code aren't downloaded on public pages. | SEO 12.2, PERF-05 |
| SEO-26 | P1 | Response headers for `/assets/*` files and for public HTML. | Hashed assets: `public, max-age=31536000, immutable`, served from the Cloudflare cache (HIT on second request). Public HTML is cached briefly and refreshed on deploy. Signed-in and API responses stay `private, no-store`. | SEO 12.3, A9 |
| SEO-27 | P1 | Public pages: check images. | Every content image has meaningful alt text and decorative images have empty alt; width and height set; modern format | SEO 11 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | | (WebP/AVIF) with fallback; below-the-fold images lazy-load and the LCP image does not. | |
| SEO-28 | P1 | Legal pages: request each "Download PDF". | PDF loads (status 200) and sends `X-Robots-Tag: noindex`; the HTML page is the canonical version. | SEO 3.6, K74 |
| SEO-29 | P0 | Load public pages in a fresh browser profile and list every cookie, storage item and third-party request before any interaction. | Only the essential items in the Cookie notice (`__cf_bm`, session, UI localStorage; `m365_consent` once a choice is made). **No analytics, advertising or tracking** requests or cookies before consent; analytics is only Plausible after Accept (suites CONS, ANL). | SEO 13, LEG-30, K79 |
| SEO-30 | P1 | Akthar or the developer with access: open Google Search Console and Bing Webmaster Tools. | Domain property for margins365.com verified by DNS in both. Sitemap submitted and "Success". URL inspection of each public page shows "URL is on Google" or "indexing requested", with Google's rendered HTML showing the page content. | SEO 13 |
| SEO-31 | P2 | Two weeks after launch: Search Console Page indexing and Core Web Vitals reports. | No soft 404s, no "Duplicate without user-selected canonical" for public pages, no signed-in URLs indexed. Core Web Vitals "Good" or "Not enough data". Log the results for Akthar. | SEO 13 |
| SEO-32 | P2 | Search Google and Bing for "margins365" and "margins 365". | margins365.com is the first result, with the new title. (If not, log it; this can take days to weeks after indexing.) | SEO 14 |
| SEO-33 | P1 | Home: read the H1 in the raw HTML and on phone, iPad and desktop. | Exactly one H1: "Know your true profit and where it leaks". The Product section headline "See where your profit is leaking." is unchanged. The hero layout doesn't break (K48 scaling). | K78, 23.17 |
| SEO-34 | P1 | `/profit-leak-checklist` and `/multi-channel-profit` (Phase 2): raw HTML, metadata, | Prerendered; title, description and H1 exactly as SEO spec 15.1; canonical to | K77, SEO |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | sitemap, links. | itself; in the sitemap; linked from Home, the Help centre and the calculator pages with `<a href>`. | 15.1 |
| SEO-35 | P1 | Each published help article (Phase 2). | One H1, "Updated [date]", author "Margins365 team", sources for every fee or tax fact matching spec 16.2/16.3, "Not tax advice" on tax content, BreadcrumbList valid, in the sitemap. The VAT article has the accountant's sign-off recorded. | K77, 23.16 |
| SEO-36 | P1 | Search the site, sitemap and all copy for a competitor comparison page: request `/compare`, `/compare/trueprofit-beprofit-sellerboard`, and search for "vs TrueProfit", "alternative to". | 404 for the routes; no comparison page, link or sitemap entry exists (not approved). | K77 |

### Suite PCALC — Free public calculators (K76, spec 23.15, PC-1–PC-6) — Phase 2 release

Run when K76 is delivered, after the core v20 pass. Use the golden examples in spec 23.15 and enter the example exchange rate ($1 = £0.75) by hand where the calculator allows it, or recompute the listing fee at the shown ECB rate.

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| PCALC-01 | P0 | Etsy UK calculator: enter the Etsy golden example. | Revenue £28.95; fees £4.23 (transaction £1.88, regulatory operating fee £0.14, processing £1.36, listing £0.15, VAT on fees £0.71); return cost £0.58; CM £13.34 (46.1%); true profit £13.34 (46.1%); Healthy; break-even ROAS 2.17×; target price £11.05; break-even price £9.28. | 23.15, 12.0, 16.2 |
| PCALC-02 | P0 | Amazon UK calculator: enter the Amazon golden example. | Revenue £16.66; fees £6.10 (referral £3.00, other £3.10); return cost £0.50; CM £5.56 (33.4%); true profit £4.06 (24.4%); Healthy; break-even ROAS 3.00×; target price £15.83 including VAT; break-even price £13.83. | 23.15 |
| PCALC-03 | P0 | Shopify UK calculator: enter the | Revenue £44.99; fees £1.15; return cost £2.25; CM £24.39 (54.2%); true profit £16.39 | 23.15 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| | | Shopify golden example. | (36.4%); Healthy; break-even ROAS 1.84×; target price £25.68; break-even price £22.38. | |
| PCALC-04 | P0 | Margin calculator: enter the generic golden example. | Revenue £15.00; fees £2.46; return cost £0.60; CM £2.59 (17.3%); true profit £1.59 (10.6%); Healthy; break-even ROAS 5.79×; target price £17.85 including VAT; break-even price £15.67. | 23.15 |
| PCALC-05 | P0 | **Same engine:** upload a one-order test file to a test shop with the same figures as PCALC-03 (and an Etsy file matching PCALC-01), then compare the Control room's order figures with the calculator. | Identical revenue, fees, CM, true profit, verdict and target price to the penny. Development confirms in writing that the calculators import the product's calculation module and preset configuration (no copied formulas). | PC-2, 12.0–12.3 |
| PCALC-06 | P0 | Each calculator: enter the target price shown, then the target price minus £0.01. | At the target price net margin is ≥ 10.0%; 1p less is below 10.0%. Changing the target margin to 15% and 0% (break-even) behaves the same way. | 12.3, PC-4 |
| PCALC-07 | P1 | Rounding boundaries: choose inputs where the margin is 9.95% and 9.94%, and a money value ending in .005. | 9.95% shows 10.0% Healthy; 9.94% shows 9.9% Thin; .005 rounds up (half-up). Rounding happens only for display (totals use unrounded values). | 12.2, 12.3 |
| PCALC-08 | P1 | Losing money and Not reachable: price below costs; then return rate 50% and fees so that % costs + returns + target ≥ 100%. | Verdict Losing money with a negative profit shown clearly. Target price reads "Not reachable at this margin". Break-even ROAS reads "not reachable" when CM ≤ 0. | 12.0, 12.3 |
| PCALC-09 | P1 | Validation: negative cost, letters, blank price, price 0, return rate 150%, quantity 0. | Field-level 12.7 messages; results hidden rather than wrong; no crash; nothing sent to the server. | 12.7, PC-4 |
| PCALC-10 | P1 | Amazon: low price where 15% is under £0.25 (for example £1.20); change category to Clothing at £14, £18 and £25. | Referral becomes the £0.25 minimum; clothing rates follow the 16.2 UK table (5%, 10%, 15%). Show the maths names the rate and its source. | 16.2 |
| PCALC- | P1 | Etsy: Offsite Ads on at 15% and | Offsite Ads shows under ad spend (not fees), | 16.2, |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| 11 | | 12%; then an order large enough that 15% exceeds $100. | and is capped at $100 converted at the ECB rate. Toggling "VAT-registered" removes VAT on fees. | 12.8 |
| PCALC-12 | P1 | VAT: tick "Prices include VAT" at 20%, 5% and 0%; untick. | Revenue excludes VAT; the target price including VAT = unrounded ex-VAT target × (1 + rate), rounded up to the next 0.01. | 12.3, 16.3 |
| PCALC-13 | P0 | **Privacy:** with DevTools Network open (analytics accepted), type values into every calculator and copy the result. | No request contains any entered value (no server call, no analytics property, nothing in the URL, nothing in storage). Only a `Calculator used` event with the calculator name may be sent. | PC-3, AN-2 |
| PCALC-14 | P1 | Preset sources: open Show the maths and the fee table on each page. | Every preset shows its rate, base, source link and "last checked" date, matching spec 16.2. The estimate and "not tax or accounting advice" notice is visible above the results. | PC-5 |
| PCALC-15 | P1 | Calls to action: signed out; signed in without a plan; on a trial or paid plan. | Signed out: "start your 14-day free trial" and "Open the Sample shop". On a trial or paid plan: "Go to Control room" and **no** trial CTA (V10). | 23.15, V10 |
| PCALC-16 | P1 | Accessibility: keyboard only and with VoiceOver/NVDA; 200% zoom; phone, iPad portrait and landscape. | Every input labelled; results announced politely; no layout shift while typing (CLS < 0.1); 44 px targets; WCAG 2.2 AA (axe: no serious or critical). | 15, PC-6 |
| PCALC-17 | P1 | SEO for each calculator page: raw HTML, metadata, sitemap. | Prerendered with the default worked example visible in the HTML; title, description and H1 exactly as SEO spec 15.1; FAQPage and BreadcrumbList valid; listed in the sitemap; canonical to itself. | SEO 15.1, PC-6 |
| PCALC-18 | P2 | Preset change: in staging, change a 16.2 preset value (for example Etsy processing to 4.5%) in the shared configuration. | Both the calculator and the signed-in product use the new value with no other change; revert afterwards. | PC-2 |

### Suite CONS — Consent banner (K79, spec 23.18, AN-4)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| CONS-01 | P0 | Fresh browser profile: open Home, Pricing, a calculator and a legal page. | The banner shows on the first public page, at the bottom, without covering the H1 or blocking the page. Text as spec 23.18, with a link to the Cookie notice. | 23.18 |
| CONS-02 | P0 | Compare the two buttons. | "Accept analytics" and "Reject" have equal size, weight, colour prominence and position on every breakpoint. No pre-ticked boxes; no third "manage" path that is easier than Reject. | ICO, AN-4 |
| CONS-03 | P0 | Close the banner with X and with Escape; reload. | Treated as Reject: no analytics loads, `m365_consent` = rejected, banner not shown again on reload. | 23.18 |
| CONS-04 | P1 | Accept, then reload and visit other public pages. | Banner doesn't reappear. `m365_consent` stores accepted, the notice version and the date. | 23.18 |
| CONS-05 | P0 | Footer Legal column → **Cookie settings**: switch from Accept to Reject, and back. | Choice changes immediately. After Reject no further analytics requests are sent on this or later pages. Withdrawing takes no more steps than accepting. | AN-3 |
| CONS-06 | P1 | Set the stored date 12 months and a day back; separately, change the Cookie notice version in staging. | The banner asks again in both cases. | 23.18 |
| CONS-07 | P1 | Keyboard and screen reader on the banner and Cookie settings. | Reachable, announced with meaningful names, visible focus, focus not trapped, 44 px targets; axe has no serious or critical issues; banner causes no layout shift (CLS < 0.1). | 15, AN-4 |
| CONS-08 | P1 | Signed in on a trial plan: open `/app`, `/account/info`, then a public page. | No banner on signed-in pages. On public pages the stored choice applies. | 23.18 |
| CONS-09 | P1 | Footer on every page. | The Legal column has Terms, Privacy, Refunds & cancellation, DPA & subprocessors, Cookies and **Cookie settings**; each works. | K64, K79 |

### Suite ANL — Analytics gating and data (K79, spec 23.18, AN-1–AN-6)

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| ANL-01 | P0 | Fresh profile, DevTools Network, before any choice: load every public page. | **No request** to plausible.io or any analytics host; no analytics script in the page. | AN-1 |
| ANL-02 | P0 | After Reject, after closing the banner, and with Global Privacy Control on (`Sec-GPC: 1`; Firefox or Brave setting). | No analytics request on any page. With GPC on, the banner is not shown and nothing loads; opting in later through Cookie settings is still possible and then works. | AN-1 |
| ANL-03 | P0 | Signed in (any plan): use `/app/*`, `/account/*`, `/welcome`, `/invite/<token>`, `/sign-in`, `/reset-password` with analytics accepted. | No analytics request on any of them. | AN-1, 23.18 |
| ANL-04 | P0 | After Accept: inspect every analytics request payload. | Page URL is the canonical path with no query string, token, email or ID. Only the events Calculator used (calculator name), Start trial clicked, Sample shop opened, Contact form sent and Checkout started appear, with no personal data or entered values. | AN-2 |
| ANL-05 | P1 | In the Plausible dashboard (Akthar's account): check page views and the five goals after a scripted test visit. | Views and goals are recorded for the test visit. | AN-2 |
| ANL-06 | P0 | After Accept: list cookies and storage set by analytics. | None. Only the essential items in the Cookie notice v20.1 exist (`__cf_bm`, session, `m365_consent`, app preferences). | AN-5, LEG-30 |
| ANL-07 | P0 | Published legal texts in the analytics release. | Cookie notice, Privacy Policy and DPA & subprocessors show **Version 20.1** and describe Plausible (provider, purpose, consent basis, EU location, no cookies, 24-month statistics retention), matching the live behaviour. Until analytics is live, the site still shows v20 texts. | AN-6, LEG-10 |
| ANL-08 | P1 | Third-party requests with analytics accepted. | The only analytics host contacted is Plausible's (or a first-party proxy path to it). No Google Analytics, Meta, TikTok or other trackers. | LEG-32 |

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| ANL-09 | P2 | Performance with analytics accepted (Lighthouse, Home, mobile). | The analytics script loads asynchronously and doesn't push LCP over 2.5 s or CLS over 0.1. | SEO-24 |

### Suite ERR — Errors and empty states

| ID | P | What to do | Expected result | Ref |
|---|---|---|---|---|
| ERR-01 | P1 | 404 and 500 pages. | Branded, with the right HTTP status and a way back. No stack traces. | G1 |
| ERR-02 | P1 | The API is down (simulate it): load the Control room, Plan & billing and the contact form. | A clear error with a retry option. No blank screen and no false success. | — |
| ERR-03 | P1 | Stripe is unavailable at checkout. | A clear message. No trial is created. | 12.10 |
| ERR-04 | P1 | Every form shows an error for every server error code (400, 401, 403, 409, 413, 422, 429, 500). | A human-readable message. 429 shows a wait-and-retry message. | — |
| ERR-05 | P2 | Empty states: no shops (Scale with only one), no members, no invoices yet, no suggestions, no data. | A helpful empty state with the next action. | CR-11 |

### Suite REG — Regression of earlier decisions K22–K58

Each decision must still hold, unless v20 replaces it. Record Pass, Fail or Replaced.

| K | What must still hold | Covered by |
|---|---|---|
| K22 | Four tiers at £39, £79, £129 and £199 including VAT; annual = 10× monthly; lifetime licences already sold are honoured. *(Its 25% founding offer is still removed;* ***v20 adds a 50% founding offer for 6 months instead****, see OFF.)* | PUB-07, CHK-25, CHK-28, OFF |
| K23 | Hard unique-order limits and all the L rules | LIM |
| K24 | Tier features, history, shops, platforms, seats | CR-02, LIM-19–21, SHOP, SEAT |
| K25/K53 | TikTok: the importer stays in development. Public copy says "Excel import coming soon" | PUB-13, IMP-18 |

| K | What must still hold | Covered by |
|---|---|---|
| K26 | Light only, no dark mode | CR-09 |
| K27 | No PDF icon in the header. The PDF sits beside the results on Growth, Pro and Scale | CR-04 |
| K28/K57 | Google first, then email. Password reset | AUTH |
| K29/K51 | No Delete account button. Cancelling closes the account | PROF-07, CAN, DEL |
| K30 | Real public pages. Three settings sections | PUB-01, PROF-09 |
| K31/K39 | Managed Payments, retries, first-payment refund. Data wiped at access end, backups gone within 7 days | CHK-18–21, DEL |
| K36 | SES Stockholm. DigitalOcean London | PRIV-02, EML-18 |
| K38 | 14-day trial, card upfront, charged on day 15, one trial per account | CHK-01–10 |
| K41 | No support target or SLA | PUB-14 |
| K42 | **Replaced by V20** (founding offer brought back as 50% for 6 months) | OFF |
| K43 | Trial wording (the banner part is **Replaced** by K81: banner removed) | MOB-12, MOB-13, CHK-02 |
| K44 | "What files do I need?" and "How to use this platform" | PUB-05 |
| K45/K48 | Phone, iPad and layout rules | RESP |
| K46 | One primary call to action, "Start 14-day free trial", when signed out. **Not shown when signed in with a trial or paid plan (V10)** | NAV-01, NAV-03 |
| K47/K55 | Shops and Seats explained as plain sub-text, with no (i) or "?" | PUB-07 |
| K49/K55 | Product section copy; headline "See where your profit is leaking." | PUB-05 |

| K | What must still hold | Covered by |
|---|---|---|
| K50 | Cancellation only in-platform, by the owner | CAN, SEAT-09 |
| K52 | **Replaced by V17** (the trial is the tier you choose) | TRL |
| K54/K55 | Centring; Most popular and "Command centre" on Pro; expanded comparison. **The FAQ moves to the Help centre (V7)** | PUB-07, HELP-02 |
| K56 | The differentiation line | PUB-05 |
| K58 | **Updated by V1** (Margins365, one word) and **V21** (move fully to margins365.com) | BR, DOM |
| K59–K74 | All v20 decisions | Suites in section 3.2 (V1–V22) |
| Calculations | 12.0–12.3 unchanged | CALC |

---

## 7. How to report a defect

Use this template for every defect, one defect per report.

```
ID: DEF-[suite]-[number] (e.g. DEF-SHOP-004) Title: [Where] [what is wrong] (e.g. "Scale shop switcher: dashboard keeps shop 1 data after switching") Priority: P0 / P1 / P2 / P3 Test case: [e.g. SHOP-04] Spec reference: [e.g. V12, 12.4, S28] Environment: Staging / Production · build or commit · date and time (Europe/London) Device / OS: [e.g. iPad Air, iPadOS 19, landscape] Browser: [e.g. Safari 19.1] Viewport: [e.g. 1194×834] Account: [e.g. qa-scale-owner-02, Scale annual, founding] URL: [the exact URL] Steps: 1. ... 2. ... 3. ... Expected: [what the spec says should happen, quoting the spec where possible] Actual: [what happened] Evidence: [screenshot or video link; HAR file; email headers; Stripe event ID; server log ID] Frequency: Always / Intermittent (x of y tries) Impact: [who is affected and how: money, legal, data, security, UX] Notes / tags: [SPEC-QUESTION | EXTERNAL-CONFIG | REGRESSION | KNOWN-GAP G#]
```

Re-test each fixed defect on the same device and browser, and once more on one other device class. Close it only with new evidence.

---

## 8. Exit criteria (release is blocked until all are met)

1. **Zero open P0 and P1 defects.** P2s are only allowed with Akthar's written agreement, and each one has a fix date.
2. **Every test case has been run** and has evidence. Every "Blocked" result is resolved, or Akthar has accepted it in writing.

3. **Every known gap G1–G20** has been re-tested and passes.
4. **All legal documents are live and public**: Terms, Privacy Policy, Refunds & cancellation, DPA & subprocessors and Cookie notice. Each has a version and an effective date, **no placeholders**, and every fact matching the product (LEG-07, LEG-09, LEG-10). Registered address, company number and ICO number to be added before launch if required (UK Companies Act trading disclosures). LEG-08 is a pre-launch check, not a P0 release blocker.
5. **Payments proven in Stripe test mode:** every tier and interval, trial, day-15 conversion, cancellation with no charge, founding months 1–6 at 50% and month 7 at full price, the 101st user at full price, upgrade and downgrade, retries, refund, dispute and webhook replay. The live proofs CHK-40–42 are done with Akthar.
6. **Deletion proven:** closure at access end, the login removed, backups gone within 7 days, and a restore test that doesn't bring data back.
7. **Isolation proven:** SEC-01–SEC-04 pass for accounts, shops and roles.
8. **Email authentication passes** (SPF, DKIM and DMARC aligned) for every email, and none links to marginos.online.
9. **Screenshot matrix complete** (RESP-01) with no fails. **Zero serious or critical axe issues**, and the keyboard and screen-reader journeys pass.
10. **The brand audit (BR-01) finds no "Margins 365", "MarginOS" or "MarginSeam"** shown to customers.
11. **The intuitiveness study (NAV-30/31) meets its targets**, or any misses have been fixed and re-tested.
12. **Every regression item (REG) passes**, or is marked "Replaced" by V-requirement.
13. **Suite SEO:** SEO-01 to SEO-29 and SEO-33 pass on production (SEO-30 to SEO-32 are post-launch checks logged for Akthar). No staging site is indexable.
14. **Suites CONS and ANL pass** (consent banner and analytics gating), and the v20.1 Cookie notice, Privacy Policy and DPA page are live with the analytics release.
15. **Phase 2 (K76, K77) has its own release gate:** every PCALC test and SEO-34 to SEO-36 pass, with zero open P0/P1 defects, before a calculator, landing page or article goes live.
16. **K80–K86:** suite MOB passes on a real iPhone (Safari, bar shown and hidden), Android phone and iPad; NAV-33–NAV-36, HELP-17–HELP-24, AUTH-21–AUTH-25, EML-22–EML-25 and OFF-17 pass; the K86 SES proof is attached.

## 9. Sign-off checklist

| # | Item | QA lead | Development lead | Akthar |
|---|---|---|---|---|
| 1 | All suites run, with evidence stored (link) | ☐ | | |
| 2 | Zero open P0 and P1 defects (defect log link) | ☐ | ☐ | |
| 3 | Known gaps G1–G20 closed | ☐ | ☐ | |
| 4 | Legal documents live, complete and accurate. Business identity | ☐ | | ☐ |

| # | Item | QA lead | Development lead | Akthar |
|---|---|---|---|---|
| | details filled in | | | |
| 5 | Stripe: test-mode suite passed; live proofs done | ☐ | ☐ | ☐ |
| 6 | Founding offer: counter, 6-month length, month 7, 101st user | ☐ | ☐ | ☐ |
| 7 | Shops, multi-shop, seats and roles fully working | ☐ | ☐ | |
| 8 | Cancellation (optional reason) and deletion proven | ☐ | ☐ | |
| 9 | Help centre contact form delivers both emails, the pop-up works, abuse limits hold | ☐ | ☐ | |
| 10 | Margins365 brand and the move off marginos.online complete (site, emails, Stripe, Google, SES) | ☐ | ☐ | ☐ |
| 11 | Responsive matrix, accessibility and performance pass | ☐ | | |
| 12 | Security and privacy checks pass | ☐ | ☐ | |
| 12a | Suite SEO passes; Search Console and Bing verified, sitemap submitted | ☐ | ☐ | ☐ |
| 12b | Consent banner and analytics gating pass (CONS, ANL); v20.1 legal texts live | ☐ | ☐ | ☐ |
| 12c | Phase 2: calculators pass PCALC (same results as the product); landing pages and articles pass SEO-34 to SEO-36 | ☐ | ☐ | ☐ |
| 12d | K80–K86: pop-ups on phones, banner removed, instant top, Suggest a feature and Contact us reach info.marginos@gmail.com, forgot password end to end, SES proof attached | ☐ | ☐ | ☐ |
| 13 | Release approved | | | ☐ |

Only Akthar's sign-off on row 13 releases the build. Marketing gets nothing until it is built, working and tested.

## 10. Spec gaps and contradictions found while writing this prompt

Spec v20 (section 23) settled most earlier questions: founding places and annual handling, the Sample shop buttons, member permissions, removing shops, ownership transfer, where cancellation reasons are kept, the contact-form rules and onboarding. The points below are still open, or are risks QA must watch. Log each as a `SPEC-QUESTION` if it is still open when testing starts.

| # | Gap or contradiction | Effect on testing |
|---|---|---|
| 1 | **The live build stores product data in the browser** (localStorage `marginos.*`), and has no server endpoints for uploads, shops, seats, cancellation, the portal, export or the contact form (G7, G8; spec finding F1). v20 23.0 requires the server to be the source of truth. | Most of SHOP, SEAT, LIM-08, LIM-15, CAN-07 and DEL are expected to fail until this is rebuilt. It is the biggest build risk. |
| 2 | **Resolved by K81 (banner removed).** Previously: the sticky banner stayed "From £39/mo" (K43, word for word) while the founding price is £19.50. That is lawful as a standard-price statement, but it is inconsistent with the founding line on Pricing. | PUB-15. Akthar to confirm the banner wording is kept. |
| 3 | **Grammar in an approved string:** "Your plan includes [n] seats" reads "1 seats" on Starter and Growth. | SEAT-02. A copy fix ("1 seat"). |
| 4 | **Addressed by K84 (confirmation without the message text; needs Akthar's OK).** Previously: the copy to the visitor repeated their message to any address typed in. That can be used to send spam under the Margins365 domain (up to 3 an hour per address and 5 an hour per IP, so it can be spread across many IPs). It risks the SES account and how trusted margins365.com mail is. | HELP-09. Recommend sending the copy only to verified signed-in users, or leaving the message body out for signed-out senders. Needs Akthar's decision. |
| 5 | **info.marginos@gmail.com** keeps the old "marginos" name, is a personal Gmail, and is published in Terms v20 as the contact address. Google becomes a recipient of contact data, so it must be listed in the Privacy Policy and the DPA/subprocessor list. | DOM-01, LEG-10, HELP-15. Allowed under K65; recommend a margins365.com address later. |
| 6 | The trading name in the v20 legal documents is **Margins365**. Company type, country of registration, registered address, company number and ICO registration number have been removed for now. Registered address, company number and ICO number to be added before launch if required (UK Companies Act trading disclosures). | LEG-08 is a **pre-launch check, not a P0 release blocker**. |

| # | Gap or contradiction | Effect on testing |
|---|---|---|
| 7 | **Only Terms and Refunds & cancellation exist as v20 files** in `/workspace/v20/`. Privacy Policy, DPA & subprocessors and the Cookie notice v20 (named in K74) were not found yet. | LEG-01, LEG-10, LEG-11, LEG-30–33 can't pass until they are published. |
| 8 | **Cloudflare is in use** (the `__cf_bm` cookie). The v20 Cookie notice and DPA subprocessor list now include it; Privacy also lists Cloudflare as a recipient. | LEG-10, LEG-30: confirm the published documents still match the live cookies. |
| 9 | **The v19 tests replaced by v20** (L17, S36–S46, D13, the K42 "no founding" checks S3, S24, 10.1.11, 22.12.8 and 16.4.3, and the 3.2 FAQ answers about the Pro trial) must be marked Replaced, not reported as fails. | REG, TRL. |
| 10 | **marginos.online now 301-redirects keeping the path and query** (re-checked 11 Nov 2026, 14:27 Europe/London; www.marginos.online fails TLS), and K73 says the redirect stops when the domain is cancelled. Every old link will then break, and someone else could register the domain. | DOM-05, DOM-06. Recommend keeping it registered but parked. |
| 11 | **The Stripe statement descriptor** `LINK.COM* MARGINOS` may be controlled by Link or Managed Payments. | BR-06. Tag it `EXTERNAL-CONFIG` for Akthar. |
| 12 | **The webhook sets ended subscriptions to "free"** (G9), and the old founding-price fields equal the full prices (G11). | CHK-30, OFF-16. |
| 13 | **The account button falls back to the email** until a business name is saved (23.1). Akthar asked for the business name, not the email. First-run makes the business name required, so this case should be rare. | NAV-08. Low risk; noted for Akthar. |
| 14 | **Contact messages are kept 12 months**, both in the database and in the Gmail mailbox. Deleting them from Gmail is a manual step. | HELP-12. Needs a manual procedure, or the Privacy wording must reflect it. |

---

*Prepared by Business & Product for Akthar Uddin. Requirements and tests only: no code, no UI design, no changes to the site.*